THE AI DATA LEAK

How to Stop Sensitive Business Information from Escaping Through AI Tools



PROTECT CUSTOMER DATA

SAFEGUARD CONFIDENTIAL INFORMATION

EMPOWER YOUR TEAM

SUPPORT GDPR & AI ACT COMPLIANCE

ZIRLANDIA MILKOVIC

PRACTICAL GUIDANCE FOR A SAFER AI FUTURE



THE

AI DATA LEAK

How to Stop Sensitive Business Information from Escaping Through AI Tools

ZIRLANDIA MILKOVIC

PROTECT CUSTOMER DATA · SAFEGUARD CONFIDENTIAL INFORMATION · EMPOWER YOUR TEAM

The AI Data Leak

How to Stop Sensitive Business Information from Escaping Through AI Tools

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for copying the checklists, templates and policy text for your own business use.

EDUCATIONAL USE ONLY. This book is a general educational guide to the EU General Data Protection Regulation (Regulation (EU) 2016/679), the UK GDPR and the EU AI Act (Regulation (EU) 2024/1689, as amended). It is not legal advice. It does not create a lawyer-client or consultant-client relationship, it does not take your individual circumstances into account, and the author is not presented as a lawyer, a certified data protection officer or a regulator. Using this book, its templates or its policy text does not make a business GDPR-compliant and is not a certification, an audit or a guarantee of compliance.

THE LAW MOVES. Legal research for this edition closed on 24 October 2026. Data protection and AI law, regulator guidance, court cases and provider terms change often, and national rules differ between countries. Check the sources listed in Chapter 12 and the Sources section, and take advice from a qualified professional before relying on anything here for a decision with real consequences.

Product and company names (including AI providers) belong to their owners and are used only for identification and education. This independent book is not affiliated with, sponsored or endorsed by any of them. Statements about provider settings and terms were taken from the providers' own public documentation on the dates shown in the References section and may have changed since.

All people, businesses and incidents in the scenarios are fictional and were invented to illustrate ideas. They are not real enforcement cases.

Kindle Edition 2026 · Legal research cut-off: 24 October 2026

Contents

Info	Educational and Legal Disclaimer	5
Intro	The Data Leak You Never Saw Coming	6
01	How AI Data Leaks Really Happen	10
02	The Information You Should Think Twice About Sharing	17
03	What Happens After You Press Enter?	25
04	ChatGPT, Copilot, Gemini, Claude: How to Choose More Safely	31
05	GDPR and AI: What Small Businesses Need to Understand	39
06	The AI Mistakes That Can Expose Your Business	50
07	Build an AI Privacy Policy Your Employees Can Follow	63
08	AI in Marketing, HR, Customer Service, Finance and Software	70
09	What to Do If You Have Already Shared Sensitive Information	76
10	The EU AI Act and the Future of Business Privacy	87
11	The 30-Day AI Privacy Protection Plan	94
12	Your AI Privacy Toolkit	103
End	Make AI Work for Your Business, Not Against It	114
Ref	Sources	117
Bio	About the Author and GDPRGard.eu	121

Educational and Legal Disclaimer

Please read this page before you use anything else in the book.

This book is an educational publication. It explains, in plain English, how data protection law, cybersecurity practice and the EU's artificial intelligence rules relate to the everyday use of AI tools in a small business. It is **not legal advice**, it is not a substitute for advice from a qualified lawyer or data protection professional, and it cannot take account of the facts of your business.

The author is not presented as a lawyer, a certified data protection officer (DPO) or a regulator. Nothing here is endorsed or approved by any supervisory authority, the European Commission or any AI provider. Completing a checklist, adopting the sample policy or filling in a template does **not** make a business compliant with the GDPR, the UK GDPR or the AI Act, and does not guarantee any outcome in an audit, a complaint or an investigation.

Three things can change after publication:

- **The law and its dates.** Legal research for this edition closed on **24 October 2026**. The EU AI Act was amended in July 2026. Changes to the GDPR have been proposed but, as far as the research found, not adopted. The Sources section lists what to re-check.
- **Provider settings and terms.** Statements about AI providers are taken from their own public documentation on the dates shown in the Sources. Products, plans, defaults and contracts change, sometimes without notice.
- **National rules.** The GDPR applies across the EU and the wider European Economic Area, but national laws on employment, health, children's data and much else differ, and every supervisory authority publishes its own guidance.

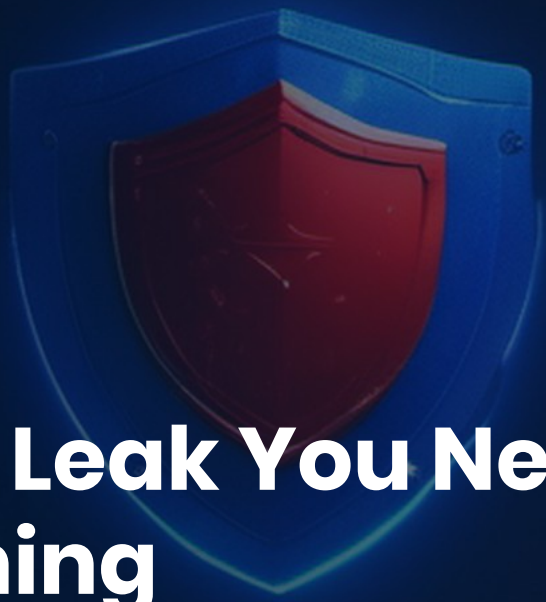
The book is written for small businesses in the **EU, the EEA and the United Kingdom**. The EU GDPR and the UK GDPR are close cousins but separate laws, enforced by different regulators, and the EU AI Act has no UK equivalent. Where they differ in a way that matters, the text says so. Where it says "the GDPR" without qualification, the point holds under both.

> WATCH OUT **When to get professional help**
>
> Take specialist advice before you rely on this book for a decision about special-category data, children's data, employee monitoring, automated decisions about people, large-scale profiling, cross-border group structures, a suspected data breach with real risk to people, or a contract with a significant AI provider.

INTRODUCTION

INTRODUCTION

AI



The Data Leak You Never Saw Coming

Nobody hacked the business. Somebody simply asked for a summary.

IN THIS CHAPTER

- How an ordinary, well-meant AI request can put customer information at risk
- What this book promises, who it is for, and what it does not claim
- The five questions it answers, and how to use the tools inside it

It is a quiet Tuesday afternoon at Harrow & Finch, a fictional eleven-person interior design studio. Maya, the studio's office coordinator, has forty minutes before a client call. In her inbox is a 38-page email thread, forwarded by a colleague, about a delayed kitchen installation. It includes the customer's name, home address, phone number, photographs of the house, a payment dispute, and a remark that the customer's mother, who lives with them, has been unwell.

Maya does what thousands of capable people do every day. She opens a free AI assistant in her browser, signed in with her personal account, pastes the whole thread and types: *summarise this and draft a reply*. Ten seconds later she has a tidy summary and a polite draft. She edits the draft, sends it, and goes to her call.

Nothing visibly goes wrong. No alarm sounds. No file is lost. Maya has not broken into anything, and nobody has stolen anything.

Three weeks later the customer asks, in writing, which companies have received their personal data. Nobody at the studio can answer with confidence. The owner discovers that there is no record of which AI tools staff use, no rule about what may be pasted into them, and no way of knowing what the provider's consumer terms say about keeping or reusing the conversation. The honest answer to the customer is: *we do not know*. That is awkward, and it is a problem in its own right.

This is a fictional illustration, and it is deliberately modest. It does **not** show that every AI interaction is a breach, that Harrow & Finch broke the law by pasting an email into a tool, or that a regulator would automatically act. Whether the studio did anything unlawful depends on facts the story does not give: which tool and plan, what its terms said, whether staff had been told what to do, whether the customer's information was necessary for the task, and what happened to the conversation afterwards. What the story does show is the real risk. **The information left the studio's control in ten seconds, and nobody had decided in advance that it should.**

The leak that has no hacker

When people imagine a data leak, they imagine criminals. The leaks this book deals with look different. They are quiet, they are caused by helpful people doing their jobs, and they often leave no trace until someone asks a question you cannot answer. A document pasted into a chat window. A spreadsheet uploaded to a free analysis tool. A browser extension that can read every page you open. An integration that was connected on a Friday afternoon and forgotten.

The causes are rarely technical. They are usually a missing rule, a missing setting or a missing habit. That is good news, because all three can be fixed in a small business without a security team, a legal department or a large budget.

The paste
Someone puts text into a tool before anyone has asked whether it should go there.

The upload
A file arrives with more in it than anyone noticed: hidden sheets, comments, metadata, other people's details.

The connection
An integration, plug-in or extension gets standing access to mail, files or customer systems.

The output
An AI-generated summary, report or reply carries confidential details to people who should not see them.

Figure 1 Four ways information typically escapes through AI tools

What this book promises

AI tools can make a small business faster, and this book is not against them. It is a practical manual for using them **without unnecessarily exposing the information your business is trusted to protect**: customer and employee data, confidential documents, financial records, source code and trade secrets.

It is organised around five questions that business owners ask:

1. **What should I never paste into an AI tool without authorisation and safeguards?** Chapter 2 and the Green, Amber and Red framework.
2. **How can I use ChatGPT and other AI tools without exposing confidential information?** Chapters 3, 4 and 8.
3. **What should I check before letting employees or contractors use AI?** Chapters 4, 7 and 11.
4. **How do GDPR, cybersecurity, vendor contracts and the EU AI Act affect a small business?** Chapters 5 and 10.
5. **What do I do if sensitive information has already gone in?** Chapter 9.

What it does not promise

It does not promise that you can become risk-free or fully compliant by reading a book, and it will not tell you that a particular tool is "safe" or "GDPR compliant". Compliance belongs to the **organisation that uses a tool for a particular purpose**, and it depends on the data, the contract, the settings and the people. A provider's privacy commitments are valuable evidence. They are not a verdict on your use.

It also avoids fear. Few of the scenarios in this book are catastrophic, and many are fixable in an afternoon. The aim is calm, proportionate decisions made **before** the data goes in.

Who it is for

The book is written for owners and managers of small businesses and for the people who work with them: entrepreneurs, freelancers, consultants, marketing agencies, online sellers, small software companies and teams of two to fifty. You do not need technical knowledge. You do not need a lawyer to start, although the book says clearly when you will want one.

How to use the tools inside it

Every chapter ends with a short **action list**, and most contain a **"What this means for your business"** summary so that you can take the point and move on. Decision tools, checklists and templates are placed where they are needed. The complete set is gathered in Chapter 12, and the editable PDF edition lets you type into the forms. Each tool is a starting point: adapt it, date it, and keep it.

THE IDEA BEHIND EVERY CHAPTER

Before information goes into an AI tool, ask four questions: what is it, why am I using it, who else will handle it, and what happens to it afterwards?

PRACTICAL TIP **If you have only an hour**

Read Chapter 2, tick the checklist at the end of Chapter 1, and carry out the five actions in the Conclusion. That alone will close the most common gaps.

THE PROBLEM

CHAPTER

01

How AI Data Leaks Really Happen

The routes by which information leaves your control through AI tools, and why they are so easy to miss.

IN THIS CHAPTER

- What an AI data exposure is, and how it differs from a data breach
- The six routes by which information escapes: prompts, files, connections, extensions, shared spaces and outputs
- Why small businesses overlook the risk, and what providers can and cannot see
- A checklist: where could my business leak data?

You cannot manage a risk you cannot picture. This chapter gives you the picture: where information starts, where it travels and where it can slip out. It deliberately avoids technical depth. If you can follow an email trail, you can follow an AI data trail.

Four terms that are often confused

People say "data leak", "data breach" and "data exposure" as if they were the same. They are not, and the differences decide what you must do next. This book uses the following terms consistently.

Four situations, four meanings

Term	Plain-English meaning	Example
AI data exposure	Information is placed where it should not be, or could be seen or used by someone who should not have it. This is a practical term, not a legal one.	A customer list pasted into an unapproved tool.
Accidental disclosure	Someone outside the authorised group receives information because of a mistake.	An AI-written email attaches the wrong spreadsheet and goes to a client.
Excessive access	A tool, account or person can reach far more than the task needs.	An AI assistant connected to the whole shared drive when it needed one folder.
Inappropriate use	Information is used for a purpose it was not collected or entrusted for.	Staff reviews fed into an AI tool to rank employees without telling them.

A **personal data breach** is a legal term, defined in Article 4(12) of the GDPR as a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data [1]. Many AI data exposures are **not** personal data breaches. Many are. Which one you have depends on the facts, and Chapter 9 explains how to assess them. For now, remember that every personal data breach is an exposure, but not every exposure is a personal data breach.

> **IN PLAIN ENGLISH** **In plain English**
>
> An "exposure" is a warning light. A "breach", in the legal sense, is one specific thing the law tells you to handle in a particular way. Do not skip the warning light because you are unsure whether it is the second.

The path your information takes

Whenever someone uses an AI tool for work, information follows a path. Each point on it is a decision somebody made, or failed to make.

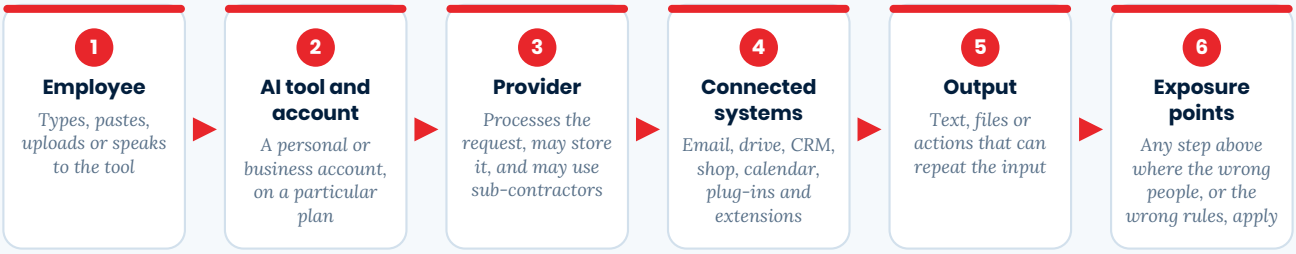


Figure 2 The journey from your employee to possible exposure

The diagram above is a map, not a verdict. Most journeys end safely. The value of the map is that it shows you six places to check, which we now take in turn.

Route 1: the prompt

A **prompt** is whatever you type, paste or say. It is the most direct route and the one most people think of. A prompt is dangerous not because AI is sinister but because it is **frictionless**. Sending a sensitive email to an outsider needs an address, a decision and a click on Send. Pasting the same email into a chat window needs only a keystroke, and it feels like thinking aloud.

Prompts also grow. A short question becomes a thread, then a document, then a whole conversation that is saved in the account's history. What you pasted on Monday is still sitting there on Friday, visible to anybody who can open that account.

Route 2: the uploaded file

Files carry more than meets the eye. A spreadsheet may have hidden sheets, a document may have tracked changes and comments, a PDF may contain a scan of someone's passport on page nine, and an image may have location data stored in its metadata. The person uploading it often sees only the first screen.

Files also arrive in bulk. Uploading a folder to ask "what are the common themes in these customer complaints?" is a single action, but it may contain hundreds of people's details.

Route 3: connected applications and integrations

Many AI tools can be **connected** to your email, calendar, shared drive, CRM, accounting package or online shop. The connection is the point: it lets the assistant answer questions about your own information. It also means the tool can read, and sometimes change, a great deal without anyone pasting anything.

Two questions matter. *What can it reach?* and *what can it do?* A tool that can only read one folder is one thing. A tool that can read all mail, send messages and edit documents is quite another, and an error or a malicious instruction could cause harm quickly. Security researchers describe one risk here as **prompt injection**: text in an email, web page or document that is written to trick an AI assistant into following the attacker's instructions instead of yours. The OWASP project ranks it among the leading risks for applications built on language models [13]. The practical lesson for a small business is to give connected tools the **least access that works** and to be wary of any assistant that can both read untrusted content and take actions.

Route 4: browser extensions and add-ons

Browser extensions that "summarise any page" or "write your emails" often need permission to **read and change the pages you visit**. That can include webmail, your accounting software and your customer database. An extension installed by one enthusiastic employee is invisible to everyone else. Treat an extension that asks for access to "all websites" as you would a stranger asking for a copy of your office keys.

Route 5: shared workspaces and shared links

Some AI tools let you **share a conversation** by link, or work in a team space. A shared link can be convenient and can also be forwarded, indexed or left open. Team workspaces help only if someone has decided who belongs in them. Former staff and freelancers often keep access longer than anyone intended.

Route 6: the output

The exposure does not always come on the way in. AI output can repeat confidential details from the input, quote from connected documents, or combine information so that something previously separate becomes sensitive. An assistant asked for a "client update" may pull a figure from a folder the client should never see. The output is then pasted into an email, a proposal or a public post, and the leak is complete. Chapter 6 shows this in practice.

The human factors behind the technology

Almost every scenario above has a human cause that is far more ordinary than a technical failure:

- **Unclear rules.** Nobody told staff what is allowed, so each person decides alone.
- **Time pressure.** The task is urgent, the approved tool is slow or missing, and the free one is one tab away.
- **Misplaced trust.** A polished answer feels authoritative, and a friendly chat window feels private.
- **Invisible settings.** Whether chat history is saved, or whether content may be used to improve a product, sits in a menu nobody opened.
- **Good intentions.** People paste data to do a better job, not a worse one.

It follows that blame is a poor tool. If people are afraid to admit what they have done, you will hear about it last. A business that responds to an honest report with "thank you, let us fix the process" will find problems earlier than one that responds with a telling-off.

Why small businesses overlook the risk



Figure 3 Four reasons the risk hides in small teams

What AI providers can and cannot necessarily see

It helps to be exact here, because the answer is neither "they see everything" nor "they see nothing".

- **Different products, different rules.** Providers sell several products under one brand: free consumer apps, paid personal plans, business or enterprise plans, and developer interfaces. Retention, human review, use of content for training and available contracts can differ between them [10][11][12].
- **Not every provider trains on every prompt.** Some say, for their business products, that customer content is not used to train foundation models by default or without instruction. Others use consumer content to improve services unless the user opts out. You must read the terms for the **specific product and plan** you use.
- **Deleting a chat is not always deleting everything.** Removing a conversation from your history may not immediately remove every copy, log or backup, and some data may be kept for safety, legal or support reasons. Providers document retention periods separately.

- **Staff at the provider may sometimes have access.** Some products allow limited human review for safety or abuse checks, or for support. Whether and when depends on the product, so ask.
- **Your own people see more than the provider does.** In practice, the people who can open an account, a shared link or a connected folder are the most likely route to exposure.

> **WATCH OUT** **Do not rely on assumptions**
>
> "Everyone uses it", "it has a privacy setting" and "I deleted the chat" are not evidence. Evidence is the provider's written terms for your plan, the settings you checked, and a record that you checked them.

What this means for your business

- Exposure can happen without any attack. Convenience is enough.
- The six routes are prompts, files, connections, extensions, shared spaces and outputs. Check each one.
- The plan and account matter as much as the brand.
- Blame discourages reporting. Ask people what they use and thank them for honesty.

WHERE COULD MY BUSINESS LEAK DATA? (TICK EVERY STATEMENT THAT IS TRUE TODAY)

- [ ] Staff use AI tools with personal accounts for work tasks.
- [ ] Nobody has written down which AI tools are approved.
- [ ] People paste customer or client details into AI tools.
- [ ] Staff upload spreadsheets or documents without checking for hidden sheets, comments or metadata.
- [ ] An AI tool is connected to email, shared drive, CRM or online shop.
- [ ] Someone has installed a browser extension that reads web pages.
- [ ] Chat history or sharing links are switched on and nobody has reviewed who can see them.
- [ ] Freelancers or former staff still have access to a shared AI workspace.
- [ ] AI output is sent to clients or posted publicly without a person reading it closely.
- [ ] We do not know whether our tools use our content for training or how long they keep it.
- [ ] Passwords, API keys or tokens have, at some point, been pasted into a chat or a prompt.
- [ ] Nobody is responsible for deciding how AI is used.

0 to 2	3 to 6	7 or more
Low visible exposure	**Moderate exposure**	**High exposure**
Good. Write down your rules, check them each quarter, and read Chapter 4 before adding new tools.	Start with Chapter 2 and the Green, Amber and Red framework. Remove personal accounts from work use.	Take the five actions in the Conclusion this week, then follow the 30-day plan in Chapter 11.

Figure 4 How to read your ticks

GOOD PRACTICE **Chapter 1 action points**

Ask your team, kindly, which AI tools they use for work, including free accounts and phone apps. Write the answers down. Tick the checklist above and note the three statements you would most like to turn into "false".

WHAT TO PROTECT

CHAPTER

02

The Information You Should Think Twice About Sharing

Which kinds of information deserve a pause before they go into an AI tool, and what to do instead.

IN THIS CHAPTER

- The kinds of information that carry the most risk, with realistic examples
- Why context matters as much as content
- Safer alternatives: minimisation, redaction, anonymisation and synthetic data
- Why removing a name rarely makes information anonymous
- A Green, Amber and Red framework you can adapt, and a decision tree

There is no master list of "forbidden" data. The same sentence can be harmless in one setting and serious in another. What matters is **what the information is**, **who it is about**, **why you are using AI** and **which tool and plan will receive it**. This chapter helps you recognise the types of information that need extra thought, then gives you a simple system for deciding.

Three kinds of sensitive information

Business owners often use "confidential" and "personal" interchangeably. The law does not, and the difference decides which rules apply.

Personal data, special-category data, confidential information and trade secrets

Kind	What it is	Why it matters
Personal data	Any information relating to an identified or identifiable person (GDPR Art. 4(1)): names, emails, addresses, phone numbers, IP addresses, customer numbers, photos, voice recordings, and combinations that point to one individual [1].	The GDPR applies. You need a lawful basis, must be transparent and must keep it secure.
Special-category data	Data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data used to identify someone, health data, and data about sex life or sexual orientation (Art. 9) [1].	Processing is prohibited unless a specific condition applies. Treat it as Red by default.
Confidential business information	Anything you have a duty, contractual or practical, to keep private: pricing, client files, negotiations, plans, supplier terms, source code.	Not governed by the GDPR as such, but by contracts, NDAs and your own interests.
Trade secrets	Information that is secret, has commercial value because it is secret, and has been subject to reasonable steps to keep it secret (see Directive (EU) 2016/943) [19].	Careless disclosure may weaken legal protection, because "reasonable steps" is part of the test.

Data about criminal convictions and offences has its own regime (Art. 10) and usually needs a specific legal basis under national law, so treat it with the same care as special-category data.

IN PLAIN ENGLISH The same information can be more than one kind

A customer's email complaining about a medical device is personal data (the email address), possibly special-category data (health details), and confidential business information (your product defect). One paste, three regimes.

Nine types of information that deserve a pause

The examples below are realistic, not alarmist. For each, the question is not "can I never use AI?" but "what is the safer way to get the same help?"

1. Customer names, addresses, emails and phone numbers

The most common data in any business, and the most commonly pasted. A name and email on their own are personal data. Together with an order history, a complaint or a delivery address, they paint a detailed picture of someone's life. **Safer way:** replace identifiers with placeholders such as [CUSTOMER] and [ORDER], or describe the situation instead of quoting the message.

2. Identity documents and payment information

Passports, driving licences, national ID cards and utility bills allow identity fraud. Card numbers and bank details allow direct financial harm, and card data is also subject to payment-industry contractual rules. **Safer way:** never paste or upload these. If a task seems to need them, the task probably belongs in a dedicated, secured system rather than an AI chat.

3. Health information and other sensitive personal data

A sick-note in an email, a dietary requirement that reveals a religion, a union membership mentioned in a grievance: sensitive data hides in ordinary documents. **Safer way:** strip it before you start, and do not use general AI tools for any task whose purpose is to process such data without specialist advice.

4. Employee records, payroll and performance reviews

Employee data is personal data with a built-in power imbalance, and employees rarely feel able to refuse. Salary, disciplinary records, absence reasons and appraisal notes are sensitive in practice even where they are not special-category. **Safer way:** use AI to draft a *template* appraisal or policy, not to analyse a named person's record. Chapter 8 returns to this.

5. Customer complaints and support tickets

Tickets contain free text, and free text contains everything: names, order numbers, health remarks, anger, sometimes passwords. **Safer way:** summarise themes from a redacted sample, and keep any tool connected to your helpdesk tightly scoped.

6. Contracts, legal correspondence and confidential negotiations

A contract may contain the other side's confidential terms, and an NDA may prohibit disclosure to third parties, which can include an AI provider. Legal advice may also be privileged, and sharing it carelessly can complicate that protection. **Safer way:** check the confidentiality clause first; use an approved tool; or ask the AI for general explanations of a clause type rather than pasting the agreement.

7. Financial statements, passwords, API keys and access tokens

Unpublished accounts, forecasts and bank details are commercially sensitive. Credentials are different: **a password or key pasted into a prompt is a security incident waiting for a trigger**, because anybody with the key has the access. **Safer way:** never paste credentials, ever. Describe the error and paste the code with secrets removed.

8. Product roadmaps, source code and unpublished intellectual property

Your future plans, code and designs are your competitive edge. Code also often contains embedded secrets such as connection strings and keys. **Safer way:** share the minimum needed snippet, remove secrets, and use tools your business has approved for development work.

9. Supplier information and commercially sensitive documents

Supplier price lists, margins, tenders and terms are often covered by confidentiality duties to the supplier. **Safer way:** use anonymised figures, or work from public information and your own summaries.

Context counts as much as content

Four factors change the answer for the same piece of information:

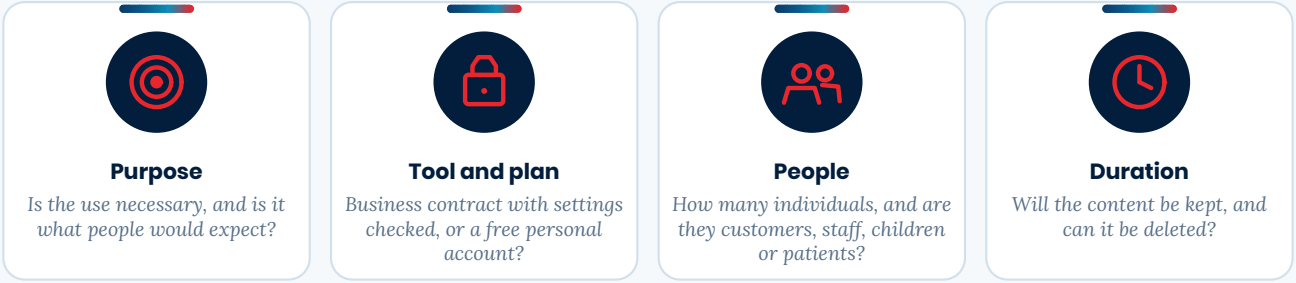


Figure 5 The four context factors

The safer alternatives

Data minimisation

The GDPR's principle of **data minimisation** says personal data must be adequate, relevant and limited to what is necessary (Art. 5(1)(c)) [1]. It is also the best habit for AI. Before pasting, ask: *what is the smallest piece of information that still lets the tool do the job*? Often it is a sentence of description instead of a pasted thread.

Redaction

Redaction means removing or blacking out sensitive parts. Done well, it is effective. Done badly, it is theatre. A black rectangle drawn over text in a PDF editor may leave the text underneath intact. Chapter 12 includes a redaction checklist.

Anonymisation

Truly **anonymous** information falls outside the GDPR, because it no longer relates to an identifiable person (Recital 26) [1]. The bar is high: you must consider all the means reasonably likely to be used to identify someone, by anyone. The EDPB's Opinion 28/2024, on AI models, stresses that anonymity must be assessed case by case [5].

Pseudonymisation

Pseudonymisation replaces identifiers with codes while a key, kept separately, can reverse them. It reduces risk but, in general, pseudonymised data is **still personal data** because re-identification remains possible for whoever holds the key. A 2025 judgment of the Court of Justice, *EDPS v SRB*, discussed how the position may differ depending on whose perspective is taken and whether the recipient can re-identify; do not rely on it without advice [17].

Synthetic data

Synthetic data is invented data that looks like real data: made-up customers with made-up orders. It is excellent for testing prompts, writing templates, training staff and trying a workflow before real data goes near it. It is only safe if it is genuinely invented. "Real data with the names changed" is not synthetic.

NAME REMOVED

- "A 52-year-old finance director at a nine-person firm in a small town, who recently returned from sick leave, complained about invoice 44021."
- Still points to one person for anyone who knows the town or the firm.
- Likely personal data.

GENUINELY RE-WORKED

- "A customer says an invoice was wrong and asks for a corrected copy."
- The facts needed for the task remain; the details that identify do not.
- Much lower risk, and the task works just as well.

Figure 6 Why removing a name is not enough

People can be identified by a **combination** of details: job title, location, dates, rare circumstances, an order number, a writing style. Re-identification becomes more likely when the data is rich, when other data is available, and when the audience knows the people involved. Removing the name changes the label, not the person.

BEFORE & AFTER **Redacting a customer email before using AI**

RISKY	*Paste the whole message: "Hi, I'm Elena Petrova, 14 Birch Lane. My card ending 4417 was charged twice for order 88412 and I've been unwell, so please hurry. Call 0151 555 0199."*
BETTER	*"A customer says they were charged twice for one order and asks for a quick reply. Draft a polite response explaining that we will check payment records and reply within two working days."*
BEST PRACTICE	*Use an approved tool and a prompt template that already contains placeholders: "Customer: [NAME]. Issue: possible duplicate charge. Tone: warm and concise." Add real details only in your own system when you send the reply.*
WHY IT MATTERS	The better prompts describe the situation, not the person. The address, card digits, health remark and phone number were never needed to draft a reply.

The Green, Amber and Red framework

A framework only works if people can apply it in five seconds. This one has three colours. It is a **practical internal control**, not a legal classification system: the law does not use traffic lights, and "Green" does not mean "lawful". It is a way of turning your business's decisions into a rule people can remember.

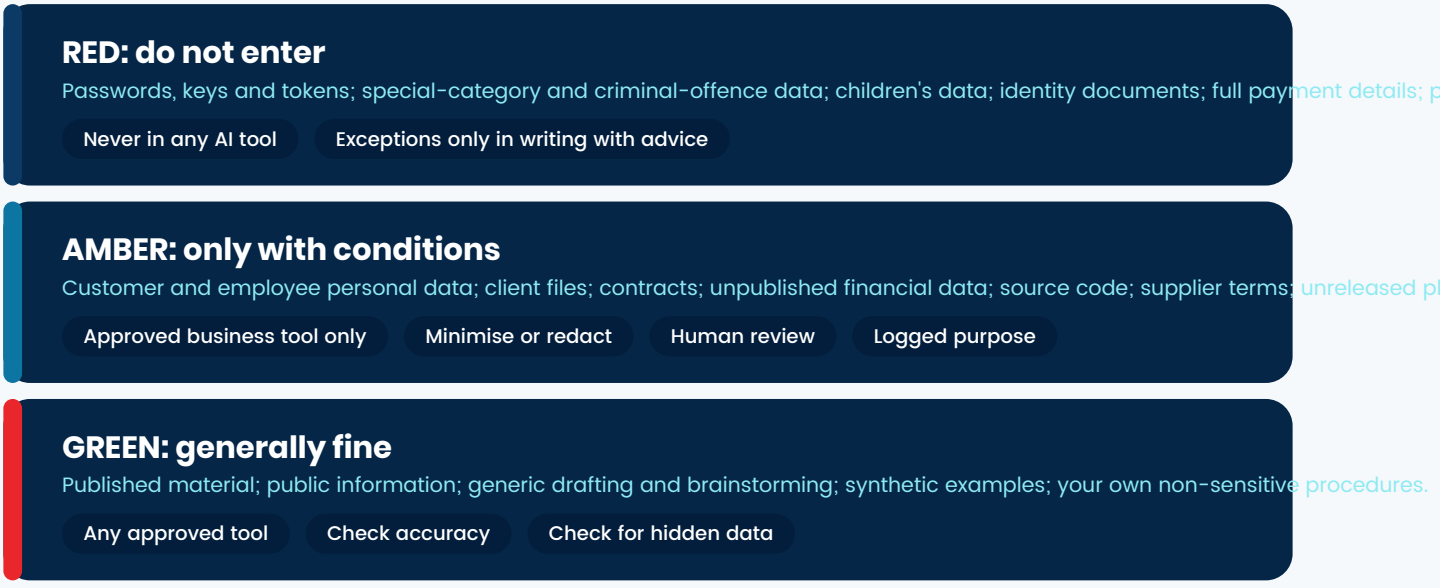


Figure 7 Green, Amber and Red information

Adapt the colours to your business. A law firm will have more Red. A florist will have more Green. What matters is that every employee can say which colour a piece of information is, and what the colour allows. Resource 3 in Chapter 12 is a matrix you can fill in.

WATCH OUT **Green is not a free pass**

Even Green information can hide something Amber. A "public" price list may include a note about one customer's discount. Look before you paste.

A decision tree for the moment before you paste

1	**Does it contain a password, key, token or other secret?**	**YES** STOP. Never paste secrets. Remove them, and change any that were already pasted.	**NO** Go to question 2.
2	**Is this tool approved by my business for this purpose?**	**YES** Go to question 3.	**NO** STOP. Use an approved tool, or ask the policy owner for an exception.
3	**Does it include special-category data, criminal data, children's data or ID documents?**	**YES** STOP and take advice. Do not proceed on your own.	**NO** Go to question 4.
4	**Does it contain any personal data, including indirect details?**	**YES** Go to question 5.	**NO** Go to question 6.
5	**Can the task be done with the personal details removed or replaced?**	**YES** Do that first, then ask again from question 1.	**NO** Check that you have a lawful basis, people were told, and the tool's terms cover it. Then go to question 6.
6	**Is it client-owned, under an NDA, or a trade secret?**	**YES** Check the contract and the tool's terms before you continue.	**NO** Go to question 7.
7	**Will a person review the output before it is used, and will you keep or delete it properly?**	**YES** Proceed, and record the decision if you will repeat it.	**NO** Add a review and a retention step, then proceed.

Figure 8 Should I put this information into this AI tool?

What this means for your business

- Know the four kinds of sensitive information: personal data, special-category data, confidential information and trade secrets.
- Context matters: purpose, tool, people and duration.
- Prefer minimisation, genuine redaction and synthetic data to pasting real records.
- Removing a name does not make information anonymous.
- Use Green, Amber and Red to give your team a five-second rule.

GOOD PRACTICE **Chapter 2 action points**

Write your own Red list on one page, starting from the one above. Choose one repeated task, such as replying to customers, and rewrite its prompt so that it contains no identifying detail. Share both with your team this week.

WHAT HAPPENS TO IT

CHAPTER

03

What Happens After You Press Enter?

The typical life of a prompt inside an AI service, and the questions to put to any provider before you rely on it.

IN THIS CHAPTER

- The stages a typical AI interaction passes through
- What is general architecture and what is provider-specific
- Retention, training, human review, sub-processors, deletion and transfers explained simply
- A practical vendor checklist for any AI product

When you press Enter, the screen shows a reply in seconds. Behind the scenes, a chain of events has taken place. This chapter describes a **typical** chain. Typical does not mean universal: every provider, product and plan is different, and the only reliable source for your tool is the provider's own documentation and contract. Treat the stages below as a list of questions, not as facts about any particular service.

The typical stages

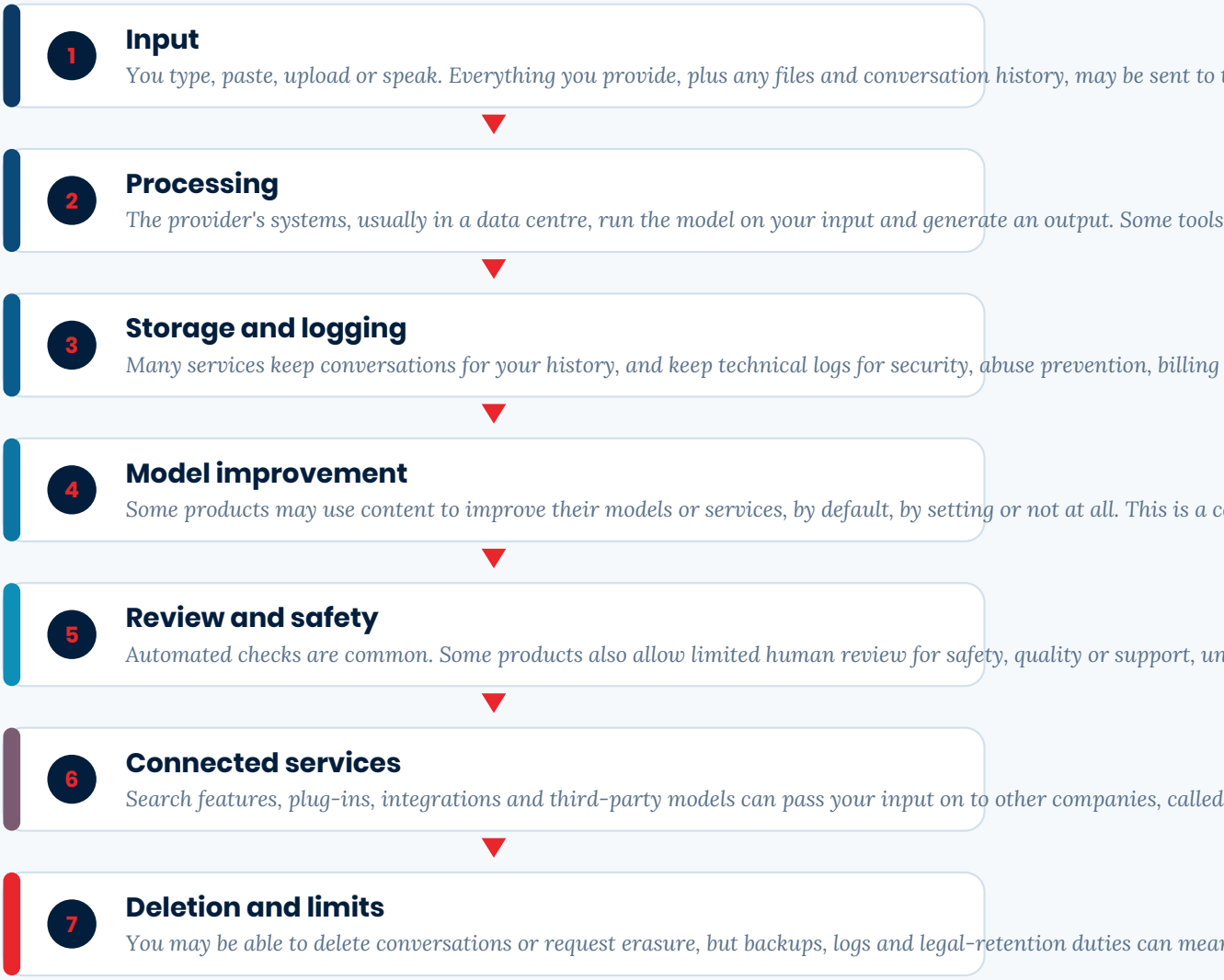


Figure 9 From keystroke to deletion request

General architecture versus provider-specific practice

It is easy to slide from "AI tools generally work like this" to "so this tool works like this". Resist it. The table separates the two.

What is generally true, and what you must check for each tool

Topic	Generally true	Provider-specific: check it
Where processing happens	Usually on the provider's or its cloud partner's servers.	Which countries; whether EU or UK processing is offered; whether the model can run locally.
Retention	Most cloud tools keep some data for a period.	How long; whether you can set it; what survives deletion.
Training	Training use of customer content is a common question.	Whether it is on or off by default for **your plan**, and whether the contract or only a setting controls it.
Human access	Providers need some staff or contractors for operations and safety.	Who may view content, in what circumstances, and under which confidentiality commitments.
Sub-processors	Large services use hosting and model partners.	The published list; notice of changes; right to object.
Deletion	Users can usually delete visible history.	Whether deletion reaches logs and backups; typical timelines.

WATCH OUT **One brand, many products**

A statement such as "we do not train on your data" often applies to a named product tier, such as a business or API plan, and not to a free or personal one. When you read a privacy page, find the sentence that says **which product it covers**.

Retention, logging and your history

Retention is how long information is kept. A provider may keep your prompts and outputs so that you can find them later, and may keep logs for fraud and abuse detection, security investigation, billing or legal reasons. Some services let administrators set retention. Some publish periods in days, others in months or years, and some tie retention to feedback or flagged content. A business that uses AI with personal data must know the period, because the GDPR's **storage limitation** principle (Art. 5(1)(e)) says personal data should not be kept longer than necessary [1].

Model improvement and training

"Training" means using data to build or improve an AI model. Providers differ on whether, and how, they use customer content. Publicly, some say that content from their business and API products is not used to train their general models without the customer's permission or instruction, while consumer products may offer a setting. Feedback buttons, bug reports and flagged conversations are often treated differently from ordinary use. Read the full policy, not only the headline. An important legal point: **a provider using your data for its own purposes may be acting as a controller for that use**, which changes your position significantly. Chapter 5 explains why.

Human review and safety processes

Automated systems commonly screen prompts and outputs for abuse. Some services also allow people to read samples, for example when a user reports a problem or when content is flagged. For a business, the questions are practical: *Can a human at the provider read my content? In what circumstances? Under what duty of confidence? Can I opt out?* Microsoft, for example, states for its Copilot services that it has opted out of the human-review abuse monitoring available in Azure OpenAI [10]. That is one provider's statement about one product group, valid on its stated date, and not a general rule.

Connected apps, third parties and sub-processors

A **sub-processor** is a company that your provider uses to process your data on its behalf, such as a cloud host or a model supplier. Under the GDPR, a processor may engage another processor only with the controller's authorisation, and must bind it to the same data protection obligations (Art. 28(2) and (4)) [1]. In practice, ask where the sub-processor list is published and how you will be told of changes. Features that search the web, call plug-ins or use another vendor's model can send your input further than you expect. Microsoft's documentation, for instance, notes that models supplied by Anthropic as a sub-processor are currently excluded from the EU Data Boundary [10]. Such exceptions are exactly what a vendor check is for.

Deletion requests and their limits

You may be able to delete a conversation, an uploaded file or your whole account. You may also, as an individual, have a right to erasure under Art. 17 of the GDPR in certain conditions [1]. But a deleted item may linger in logs or backups for a set time, and some information may be kept where a legal duty or a legitimate need applies. For a business, the lesson is to **keep things out of the tool in the first place**, because deletion is a remedy, not a guarantee. Chapter 9 covers what to ask when something has already gone in.

International transfers and safeguards

If a provider processes personal data outside the EU or EEA, the GDPR's rules on **transfers** apply (Chapter V). A transfer needs a valid tool, such as an adequacy decision, standard contractual clauses (SCCs) or another safeguard in Art. 46 [1][8]. For transfers to certified US companies, the EU-US Data Privacy Framework is an adequacy decision of 2023 [9]. The General Court dismissed a first challenge to it in September 2025, and an appeal to the Court of Justice (C-703/25 P) was reported as pending at the research cut-off, so it is sensible for businesses to know whether their provider also offers SCCs as a fallback [9].

For UK businesses, restricted transfers from the UK are governed by the UK GDPR and use the UK's own tools, such as the International Data Transfer Agreement or the UK Addendum to the EU SCCs, and the UK Extension to the Data Privacy Framework. Check the current position on the ICO website, because it has been changing [14][15].

> **IN PLAIN ENGLISH** **What this means in practice**
>
> You do not need to master transfer law. You need to ask the provider three questions: *Where will my data be processed? Which transfer tool do you rely on? What is your fallback if it fails?* Record the answers.

A vendor checklist you can use today

This is a short screening list for **any** AI product. It deliberately takes ten minutes, not ten hours. Chapter 12 contains the longer vendor questionnaire for tools that will handle important data.

THE TEN-MINUTE AI VENDOR CHECK

- [ ] I know the exact product and plan I am considering, not just the brand.
- [ ] The provider names a legal entity, an address and a privacy contact.
- [ ] A data processing agreement (DPA) is available and applies to my plan.
- [ ] The provider states whether my content is used to train or improve models, for my plan.
- [ ] Retention periods are stated, and I know who can change them.
- [ ] I know whether any human at the provider can access my content, and when.
- [ ] A list of sub-processors is published, with a way to be notified of changes.
- [ ] The provider says where data is processed and which transfer tool applies.
- [ ] Security documentation exists (for example independent certification, a trust centre or a security overview).
- [ ] There is an incident-notification commitment and a support route for business customers.

- ☐ I can control access: single sign-on or at least individual accounts, with administrators able to remove users.
- ☐ I have checked settings for connected apps, sharing links and history, and I have recorded the date.

0 to 5 ticks	6 to 9 ticks	10 to 12 ticks
Not ready Do not use it for personal or confidential data. Find a better-documented alternative.	**Partly ready** Use only for Green information, and ask the provider the missing questions.	**Reasonably documented** Proceed to the full questionnaire if the tool will handle Amber data.

Figure 10 How to read the result

SOURCE NOTE **Provider documents are evidence, not guarantees**

A statement on a privacy page, even a favourable one, tells you what the provider says. Your responsibility is to match it to your use, record that you did, and review it.

What this means for your business

- Think in stages: input, processing, storage, improvement, review, connections, deletion and transfers.
- Never assume one provider's practice applies to another, or one plan's to another.
- Ask about training, retention, human access, sub-processors and transfers, and write down the answers with dates.
- Deletion is a remedy, not a guarantee. Keep sensitive data out in the first place.

GOOD PRACTICE **Chapter 3 action points**

Pick the AI tool your business uses most. Run the ten-minute vendor check on it, and note which ticks you could not give. Send those questions to the provider or look them up in its documentation.

CHOOSING TOOLS

CHAPTER

04

ChatGPT, Copilot, Gemini, Claude: How to Choose More Safely

A practical method for comparing AI products by what your business actually needs, with provider statements checked on 24 October 2026.

IN THIS CHAPTER

- Why the plan matters more than the brand
- Eleven criteria for comparing any AI product
- What four widely used providers say in their own documentation, with dates
- How to choose by your requirements, not by reputation

"Which AI tool is safest?" is the question owners ask most, and it has no honest one-word answer. Safety depends on **your data, your use, your contract and your settings**. This chapter gives you a method that works today and will still work when the products change, which they will.

> WATCH OUT **There is no universally safest provider**
>
> This book does not rank providers. A tool that suits a freelancer writing blog posts may be wrong for a clinic. A business plan with a good contract can still be misused, and a modest tool used carefully can be adequate. Choose by requirements.

Consumer, business and enterprise: the first sorting question

Most large providers sell tiers. Names differ, but the pattern is similar:

Typical tiers of an AI product (patterns, not promises)

Tier	Typical features	Typical questions
Free or consumer	Personal account; terms written for individuals; settings controlled by each user.	Is content used to improve the service? Can a business even sign a DPA? Who owns the account when the employee leaves?
Paid personal	Higher limits and extra features, still an individual account.	Same questions; a higher price does not change the legal position.
Business or team	Organisation account, shared administration, business terms.	Is a DPA included? Are training and retention terms different? What can administrators see and control?
Enterprise	Single sign-on, audit logs, advanced controls, negotiated contract.	What is covered contractually, and what is only a setting?
Developer or API	Pay-per-use access for building your own tools.	Different data terms again, plus your own security duties for keys and logs.

A staff member who uses a business tool through a personal login has just stepped out of the business tier. Ensure that people sign in with company accounts, so that the contract and the settings you reviewed actually apply.

Eleven criteria for any AI product

Use the same eleven questions for every candidate. They map onto what the GDPR expects from a controller choosing a processor: sufficient guarantees (Art. 28(1)) [1].

- **1. Plan and contract.** Which plan will we use, and what contract applies to it?
- **2. Training use.** Is customer content used to train models, and under what conditions? Is this a contractual commitment or only a default setting?
- **3. Retention and deletion.** How long are prompts, files and outputs kept? Who sets the period? What happens on deletion?
- **4. Administration.** Can an administrator manage users, remove leavers, and control features?
- **5. Authentication and access.** Single sign-on, multi-factor authentication, role-based permissions?
- **6. Data processing agreement.** Is a DPA available, and does it cover this product?
- **7. Sub-processors and transfers.** Is the list published? Where is data processed? Which transfer tool applies?
- **8. Security documentation.** Independent certifications or audit reports, a trust centre, security whitepapers?
- **9. Connected apps, plug-ins, extensions and integrations.** What can they reach, who can enable them, and are they under separate terms?
- **10. Incident reporting and support.** What is the notification commitment? Is there a business support route?
- **11. Change management.** How will we know when terms, prices or tiers change?

What four providers say, and why it is only a start

The statements below were read from each provider's own public documentation on **24 October 2026**. They describe what a provider says about particular products. They are not endorsements, and they are not a statement about how any provider **actually** behaves. Pages are updated frequently. Always re-read the primary source before relying on it.

Provider statements checked against provider documentation, 24 October 2026

Provider and product	What the provider says, in summary	Page date and source
Microsoft Copilot (Microsoft 365 commercial)	Prompts, responses and data accessed through Microsoft Graph are not used to train foundation models. Interactions are stored in line with contractual commitments, and administrators can set retention with Microsoft Purview. EU traffic is described as staying within the EU Data Boundary, with models supplied by Anthropic as a sub-processor currently excluded.	Page updated 8 October 2026 [10]
Google Gemini in Workspace (business)	Google says Workspace does not use customer data to train models without the customer's prior permission or instruction. Prompts and content are customer data under the Cloud Data Processing Addendum. Retention is administrator-set: for Gemini in Workspace apps from 90 days to indefinite, and for the Gemini app 18 months by default with history on, configurable up to 36 months.	Page header 6 October 2026, footer 22 October 2026 [11]
Anthropic Claude (commercial products and API)	For commercial products, Anthropic says it does not use inputs or outputs for model training by default. Training may occur if feedback is submitted through a rating button or the customer otherwise allows it. Feedback may be retained for up to five years, de-linked from user and customer IDs.	Page dated 18 August 2026 [12]

Provider and product	What the provider says, in summary	Page date and source
OpenAI ChatGPT (Business, Enterprise, Edu and API platform)	OpenAI says that by default it does not use data from these products, including inputs and outputs, to train or improve its models, unless an organisation explicitly opts in. Data is encrypted at rest (AES-256) and in transit (TLS 1.2 or higher); Enterprise Key Management is offered. Qualifying organisations can configure retention, including zero data retention on the API platform. OpenAI says it supports customers in signing a Data Processing Addendum, and lists SOC 2 Type 2 and ISO/IEC 27001, 27017, 27018 and 27701. Data residency at rest (including Europe and the UK) is described for eligible Enterprise, Edu, healthcare and API customers, not for Business. Business offers multi-factor authentication, roles and SAML single sign-on. The page is undated, and the sub-processor list, the DPA text and the consumer plans were **not** read.	OpenAI "Business data privacy, security, and compliance" page, read via browser 24 October 2026 [23]

SOURCE NOTE **Why consumer plans are not in the table**

The statements above concern business and commercial products. Consumer products from the same companies use different terms, and in some cases those terms permit the use of conversations to improve services unless a setting is changed. If staff use a personal account, none of the business statements apply.

Notice what the table cannot tell you. It does not say whether the tool is right for health data. It does not say whether the provider's assurances cover **your** configuration. It does not tell you how the product behaves when a staff member connects an extra plug-in. That is why you still need your own checks.

Matching a tool to your requirements

Instead of asking which brand is best, write down what your business needs, then test each candidate against it. Four common profiles show how different the answers can be.

Four businesses, four sets of requirements

Business	Main data	What probably matters most
A freelance copywriter	Public material and a few client briefs	Plan terms for client confidentiality, ability to switch off history, personal account kept separate
A ten-person e-commerce shop	Customer names, addresses, order histories	DPA, EU or UK processing, admin controls, careful scoping of any link to support systems
A marketing agency with client data	Client lists, campaign data, analytics	Processor role clarity, client contract permissions, sub-processor list, access removal for freelancers
A small clinic or care-adjacent service	Health information	Probably not general AI chat tools at all without specialist advice; separate, specialist, assessed systems

Hidden changes: prices, tiers and terms

AI products change fast. A feature that was included can become a paid add-on. A default can move. A new connector can appear in your admin panel switched on. A provider may add a sub-processor or update its privacy page without you noticing. Build three habits:

- **Subscribe** to the provider's change notices and sub-processor updates where offered.
- **Re-check** your approved tools every quarter and after any major announcement.
- **Date everything.** A note that says "checked 24 October 2026, training off, 30-day retention" is worth far more than "we looked at it".

A simple scoring worksheet

Score each candidate from 0 (no evidence) to 2 (clear, documented, fits our need) on each of the eleven criteria. A tool that scores 0 on training use, retention or a DPA should not touch Amber data. This is a tool for **conversation and documentation**, not a certificate. Record the evidence next to each score.

TEMPLATE

Tool comparison worksheet

Copy this page for each tool you consider. Use evidence, not impressions.

Tool, plan and date checked

Our main purpose and the data it will handle

Training use (default, contractual or by setting) and evidence

Retention, deletion and who controls it

DPA, sub-processors and transfer tool

Access control, authentication and admin features

Connected apps, plug-ins and extensions

Security documentation found (names and dates)

Incident commitments and support route

Total score out of 22, and decision (approve, approve with limits, reject)

What this means for your business

- The plan, contract and settings decide your position, not the logo.
- Use the same eleven criteria for every product.
- Provider statements are evidence with dates. Re-read them, and do not assume they apply to a consumer plan.
- No provider is universally safest. Decide from your requirements and your data.

GOOD PRACTICE **Chapter 4 action points**

For each AI tool in use, record the plan, the account type, and the date you last read its terms. Replace any personal-account use for business purposes. Set a quarterly reminder to re-check.

THE LAW

CHAPTER

05

GDPR and AI: What Small Businesses Need to Understand

The parts of data protection law that matter when staff use AI tools, in plain English.

IN THIS CHAPTER

- EU GDPR and UK GDPR: how they differ and when each applies
- Personal data, controllers and processors, lawful bases and the core principles
- Vendor agreements, transfers, individual rights, records, impact assessments and breaches
- What the law requires, and what is only sensible precaution
- Four worked examples: shop, agency, consultant and software company

You do not need to read ninety-nine articles. You do need to know which handful of rules decide whether an AI use is defensible. This chapter walks through them in the order a small business meets them. It is a map for decisions and conversations, not legal advice, and it avoids the temptation to say that any particular use is "compliant".

EU GDPR and UK GDPR: which one applies?

The **EU GDPR** (Regulation (EU) 2016/679) applies directly in all EU member states and, through the EEA Agreement, in Norway, Iceland and Liechtenstein. It applies to organisations established in those places, and to organisations elsewhere that offer goods or services to people in the EU or monitor their behaviour there (Art. 3) [1].

The **UK GDPR** is the UK's retained version of the same law, working alongside the **Data Protection Act 2018**. It applies to organisations established in the UK and to others offering goods or services to people in the UK or monitoring them. It has been amended by the **Data (Use and Access) Act 2025**, which received Royal Assent on 19 June 2025 and has been brought into force in stages. The ICO's guidance page (updated 19 June 2026) says the changes were phased in between June 2025 and June 2026, and that the Act amends, but does not replace, the UK GDPR, the Data Protection Act 2018 and the Privacy and Electronic Communications Regulations [15][24]. The regulator is the Information Commissioner's Office (ICO), whose structure the Act also changes; check ico.org.uk for the current position [14].

EU GDPR and UK GDPR at a glance

Point	EU / EEA	United Kingdom
Core principles, rights, security duty, records, DPIAs, processors	Set out in the GDPR.	Largely the same in the UK GDPR, with some amendments.
Regulator	National supervisory authorities in each country.	The ICO (becoming the Information Commission).
Breach notification	Within 72 hours of becoming aware, where the test is met (Art. 33).	Same 72-hour rule to the ICO under UK GDPR Art. 33.
Transfers out	EU tools: adequacy, SCCs and others.	UK tools: adequacy regulations, the IDTA or the UK Addendum.
AI-specific law	The EU AI Act (Chapter 10).	No equivalent statute; reliance on existing law and regulator guidance.
Automated decisions about people	Art. 22 is a restriction with exceptions and safeguards.	Widened by the 2025 Act: more lawful bases can be used for significant automated decisions, with safeguards, but not for special-category data. Take advice before using AI to make or support decisions about individuals.

If you trade in both areas, you may be subject to both. Where this book says "the GDPR", the point holds under both unless noted. UK readers should check the points flagged and read the ICO's AI and data protection guidance, which the ICO notes is under review following the 2025 Act [14].

Personal data and the two hats of a business

Personal data is any information relating to an identified or identifiable natural person (Art. 4(1)) [1]. In AI use, that includes names in a pasted email, voices in an uploaded recording, faces in photos, and combinations that make someone recognisable. A **data subject** is the person the data is about.

The GDPR gives responsibilities to **controllers**, who decide why and how personal data is processed, and **processors**, who act on the controller's instructions (Art. 4(7) and 4(8)) [1][4]. When you paste your customers' details into a business AI tool to draft replies, you are normally the **controller** and the provider is a **processor** for that use. When you handle a client's data on the client's behalf, as an agency or a bookkeeper might, you are often the client's **processor**, and the client's instructions limit what you can do with an AI tool. The roles depend on what actually happens, not on what the contract says.

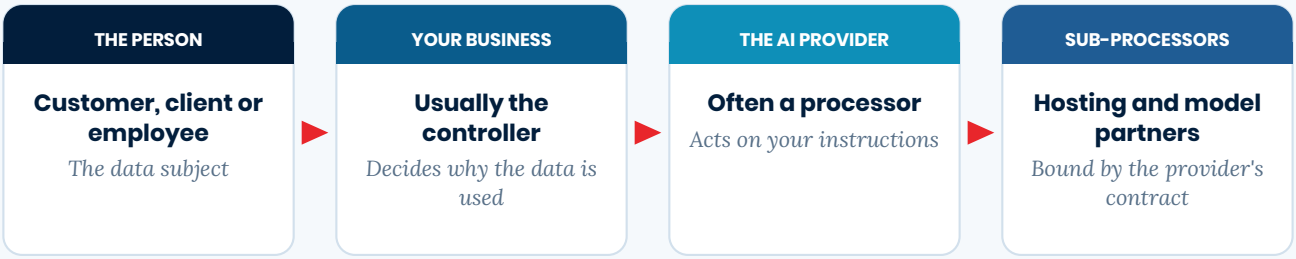


Figure 11 Who is who when a small business uses an AI tool

WATCH OUT **A provider can wear two hats**

For the same product, a provider may be your **processor** for the content you submit, and the **controller** for its own purposes, such as account administration, security or, if its terms say so, improving its services. Read which purposes are which.

WHAT THE LAW SAYS **The provider does not take over your duties**

Using a reputable provider helps. It does not transfer your obligations to it. The controller remains responsible for deciding that the use is lawful, informing people, minimising data, choosing a suitable processor and answering to the regulator. "The tool said it was GDPR compliant" is not a defence.

The seven principles, applied to AI

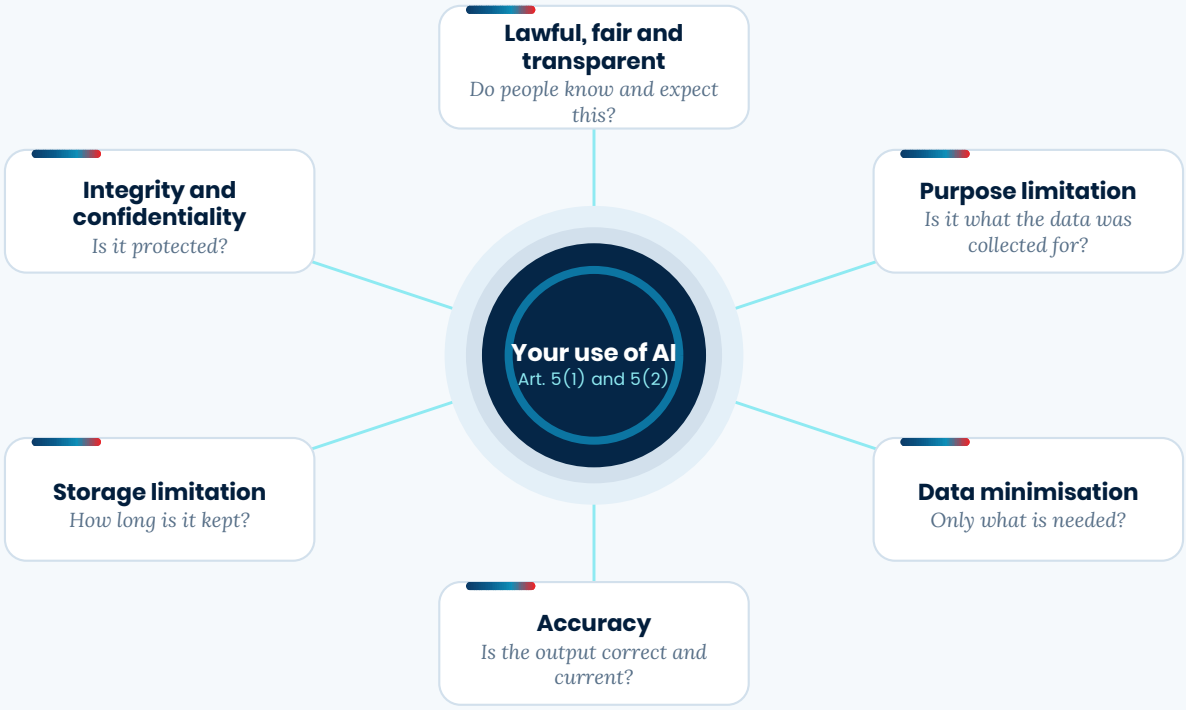


Figure 12 The principles of Art. 5, applied to AI

The seventh principle, **accountability** (Art. 5(2)), says you must be able to **show** compliance. That is why this book keeps asking you to write things down.

Lawful bases

Every use of personal data needs a **lawful basis** under Art. 6, chosen before the processing starts [1]. For small businesses, three are common in AI-related work.

Lawful bases small businesses often consider

Basis	Plain-English meaning	Typical AI example	Watch out
Contract (Art. 6(1)(b))	Necessary to perform a contract with the person or take steps at their request.	Drafting a reply about a customer's own order.	It must be necessary, not merely useful.
Legitimate interests (Art. 6(1)(f))	Necessary for your or a third party's legitimate interests, unless outweighed by the person's interests and rights.	Summarising support themes from redacted tickets.	You need a written balancing test. It is not a catch-all.
Consent (Art. 6(1)(a))	Freely given, specific, informed and unambiguous agreement.	Letting a customer opt in to an AI chat assistant.	Not valid if bundled, forced or if there is a power imbalance, as with employees.
Legal obligation, vital interests, public task	Specific, narrower cases.	Rarely the right base for ordinary AI tasks.	Do not stretch them.

The EDPB's Opinion 28/2024 considers, in the specific context of AI models, how legitimate interests may be assessed, and stresses that it needs a careful, three-step test [5]. For special-category data you also need a condition in **Art. 9(2)**, such as explicit consent or employment-law grounds. In the UK, the 2025 Act introduced a list of "recognised legitimate interests" for which no balancing test is needed, in addition to the ordinary test; see the ICO's guidance for details [15][24].

Transparency and purpose

People must be told what you do with their data (Arts 13 and 14), in concise, plain language [1]. If AI tools are part of how you handle customer or employee data, your **privacy notice** should say so at a level people can understand, typically by naming the **categories of recipients**, such as "service providers who help us operate our tools", and the purposes. A notice written in 2019 may not mention AI at all. **Purpose limitation** adds that you may not use data for a new, incompatible purpose: using customer complaints for a quite different AI analysis may need a fresh assessment.

Data protection by design and by default

Art. 25 requires you to build protection into processing, and to make the **default** settings the privacy-friendly ones [1]. For AI, that means: approve tools before use, switch off history and sharing where possible, give people the least access they need, and use minimised or synthetic data as the starting point. It is a requirement in law, but it is also simply good engineering.

Security of processing

Art. 32 requires "appropriate technical and organisational measures", taking account of the state of the art, costs, the nature of the processing and the risks [1]. For a small business that means basics done well: unique accounts and multi-factor authentication, up-to-date devices, least-privilege access, controlled sharing and staff awareness. The UK National Cyber Security Centre's Small Business Guide is a good, practical companion for UK and other readers [21]. Security is also where the GDPR meets confidentiality and trade secrets: the same controls protect both.

Processor agreements and vendor due diligence

When a processor handles personal data for you, Art. 28 requires a **written contract** that sets out the subject matter, duration, nature and purpose, the type of data and the obligations of both sides, including: acting only on your instructions, confidentiality, security, sub-processor conditions, assistance with rights requests and breaches, deletion or return at the end, and audit information [1]. Many providers include a **data processing agreement (DPA)** in their business terms. Others do not offer one for free plans. **Using a tool for personal data without a DPA, where one is needed, is a compliance gap you can avoid**. The vendor checks in Chapters 3 and 4 are how you meet the duty to use only processors providing sufficient guarantees.

International transfers

Sending personal data to a provider that processes it outside the EU or EEA is a **restricted transfer** and needs a valid mechanism (Chapter V) [1]. Chapter 3 described the main ones. Your task is to know whether a transfer happens, which tool covers it, and whether the provider documents it.

Individuals' rights

People have rights to be informed, to access their data, to have it corrected or erased in certain cases, to restrict or object to processing, to data portability, and not to be subject to certain solely automated decisions (Arts 12 to 22) [1]. AI creates two practical issues. First, **you may need to find an individual's data across tools**. If you have no list of where AI tools are used, a subject access request becomes slow and uncertain, as Harrow & Finch discovered in the Introduction. Second, **Art. 22** restricts decisions based solely on automated processing, including profiling, that have legal or similarly significant effects. The Court of Justice in the SCHUFA case (C-634/21, 2023) read this broadly, so that an automated score that strongly determines another party's decision can itself be a "decision" [18]. Using AI to shortlist, rank, score or dismiss people needs particular care, and often advice.

Records of processing

Art. 30 requires many organisations to keep records of their processing [1]. There is an exemption for organisations with fewer than 250 employees, but it **does not apply** if the processing is likely to risk people's rights, is not occasional, or includes special-category data. Most small businesses that process customer or employee data regularly should assume they need records. Adding AI tools to the record is simple: tool, purpose, data, recipients, transfers, retention, security.

Data protection impact assessments

A **DPIA** (Art. 35) is a structured assessment of risks to people, required where processing is "likely to result in a high risk" [1][7]. It is mandatory for certain cases, including systematic and extensive profiling with significant effects, large-scale use of special-category data, and systematic large-scale monitoring of public areas. Regulators publish lists of other processing that needs one, and the former Article 29 Working Party's guidance lists nine criteria, such as evaluation or scoring, vulnerable people, new technologies and large scale [7]. AI use that scores, ranks, monitors or profiles people, or uses sensitive data at scale, often meets more than one. A DPIA is **not** required for every AI use, but **deciding and recording why you did not need one** is good practice and often wise. Use the screening checklist below.

DPIA SCREENING CHECKLIST (TICK ALL THAT APPLY)

- ☐ The AI evaluates, scores, ranks or profiles individuals.
- ☐ It supports or makes decisions with legal or similarly significant effects on people.
- ☐ It systematically monitors people, such as staff, customers or the public.
- ☐ It uses special-category, criminal-offence, financial or other highly sensitive data.
- ☐ It processes large volumes of data, or data about many people.
- ☐ It combines or matches datasets from different sources.
- ☐ It involves vulnerable people, such as employees, applicants or children.
- ☐ It uses a new or unusual technology in a way people would not expect.

0 to 1 ticks	2 or more ticks	Any Art. 35(3) case
Unlikely high risk A DPIA is probably not required. Record why, and review if the use changes.	**Likely high risk** Plan a DPIA, or take specialist advice before starting.	**DPIA required** Do not start before the DPIA is complete.

Figure 13 How to read the screening result

WATCH OUT **A checklist does not replace a DPIA**

The checklist helps you decide **whether** a DPIA is needed. It is not itself a DPIA. When in doubt, take advice.

Breaches: the short version

Art. 33 requires a controller to notify the supervisory authority of a personal data breach **without undue delay and, where feasible, within 72 hours of becoming aware of it**, unless the breach is unlikely to result in a risk to people. Art. 34 requires telling the individuals where the risk is **high**. A processor must tell the controller **without undue delay** (Art. 33(2)) [1][6]. Chapter 9 explains how to assess whether an AI incident meets the test.

Legal obligation or sensible precaution?

Readers often ask: "Is this a legal requirement?" The honest answer is that some measures are required, some are strongly expected, and some are just wise. Knowing which helps you prioritise.

Requirement or recommendation?

Measure	Status	Basis or note
Lawful basis for personal data processing	Legal requirement	GDPR Art. 6
Telling people about processing, including AI tools in your notice	Legal requirement	Arts 13 and 14
Written processor contract (DPA) where a processor is used	Legal requirement	Art. 28
Appropriate security measures	Legal requirement	Art. 32
Notification of qualifying breaches within 72 hours	Legal requirement	Arts 33 and 34
DPIA where likely high risk	Legal requirement in those cases	Art. 35
Records of processing	Legal requirement for most regular processors	Art. 30
A written AI acceptable use policy	Not specifically required; strongly advisable	Supports accountability (Art. 5(2)) and security (Art. 32)
Green, Amber and Red classification	Good practice	Internal control
Quarterly vendor re-checks	Good practice	Supports Arts 28 and 32
Staff AI training	Good practice under GDPR; AI literacy duty under the EU AI Act in some cases	See Chapter 10

Four worked examples

An online shop

A five-person shop wants an AI assistant to draft replies to delivery enquiries. It is the **controller** of customer data. The lawful basis is likely **contract** for a customer's own order or **legitimate interests** for general enquiries. It must name the tool category in its notice, sign the provider's DPA, switch off training use where there is a setting, and tell staff to strip health or family remarks before pasting. A human reads every reply before sending.

A marketing agency

An agency analyses a client's customer list for campaign segments. The client is the **controller** and the agency is its **processor**. The agency needs the client's authorisation to use any AI tool with that list, which also means its sub-processors, and must follow the client's instructions. Uploading the list to a free tool without telling the client could breach the processing agreement, and may be an unauthorised disclosure.

A solo consultant

A consultant summarises interview notes for a client. The notes contain employees' opinions about their managers. Some of that information is highly sensitive in context. Even as a sole trader, the consultant must meet the GDPR, and should check the engagement contract for confidentiality limits on third-party tools, anonymise interviewees before using AI, and use a business-tier account rather than a personal one.

A small software company

A six-person software company uses an AI coding assistant. Source code is **confidential information** and a potential **trade secret**; it may include test data containing real customer records, and secrets in configuration files. The company should select a tool with documented controls, keep secrets out of repositories, use synthetic test data, restrict the assistant's access to the repositories it needs and review generated code. If the company hosts customers' personal data, it is a **processor** for those customers and must respect their instructions on sub-processors.

What this means for your business

- Check which law applies: EU GDPR, UK GDPR, or both.
- Know your role: controller, processor, or both, for each use.
- Choose a lawful basis, tell people, minimise, secure, and sign a DPA before personal data goes into a tool.
- The provider does not carry your responsibilities for you.
- Record your decisions. Accountability means being able to show your reasoning.

> GOOD PRACTICE **Chapter 5 action points**
>
> Check your privacy notice for any mention of AI tools or "service providers", and update it. List the AI tools that process personal data and mark whether you hold a DPA for each. Decide who will own the answers to subject access requests.

CASE STUDIES

CHAPTER

06

The AI Mistakes That Can Expose Your Business

Ten illustrative scenarios that show how exposure happens, what to establish first, and how to fix it.

IN THIS CHAPTER

- Ten realistic small-business situations, each with the same seven-part analysis
- The facts that must be established before anyone judges the legal position
- An immediate fix and a lasting control for every case
- The patterns that repeat across them

FICTIONAL EXAMPLE **Illustrative scenarios, not real incidents**

Every business, person and event in this chapter is **fictional**. They are invented to illustrate how problems arise and are modelled on common patterns. They are not documented incidents, and none refers to a real organisation. The legal remarks are **questions to ask**, not conclusions, because the outcome of any real case would depend on facts, contracts and national law.

Each scenario follows the same seven headings: the situation, the information at risk, what went wrong, the facts to establish, the immediate action, the lasting control and the lesson. Read them as rehearsals. Ask of each: *could this happen here, and what would we do on Monday morning?*

Scenario 1: The unredacted customer database

Fictional marketing agency, Lumen & Co.

Heading	Detail
The situation	An account manager uploads a 12,000-row customer export from a client, a regional fitness chain, to a free AI tool to "find segments for a spring campaign". The file includes names, emails, phone numbers, birth dates, membership types and a column of free-text notes.
Information at risk	Personal data of thousands of people; some notes mention injuries and medical conditions, which may be special-category health data. The client's commercial customer list.
What went wrong	The agency had no approved tool for client data and no rule about uploads. The agency acts as the client's processor, and the processing agreement forbade using unapproved sub-processors. Nobody checked the notes column.
Facts to establish	Which tool and plan, and its terms on retention and training. Whether the account was personal or business. Whether the chat or file was shared. What the contract with the client says about sub-processors and notification. Whether health data was included. Whether anyone else could access the account.
Immediate action	Stop further uploads. Record exactly what was uploaded and when. Delete the file and conversation, and ask the provider about deletion and access logs. Tell the person responsible for the client relationship, who should inform the client under the contract. Seek specialist advice because health-related data and a large number of people may be involved.
Lasting control	An approved tool for client data, written upload rules, a pre-upload redaction step, and a template clause for client contracts that says which tools may be used.
Lesson	When you hold data for a client, your freedom to use AI is limited by their instructions. The first question is not "is the tool good?" but "am I allowed?"

Scenario 2: The contract in the wrong chat window

Fictional design studio, Northgate Interiors

Heading	Detail
The situation	A project manager pastes a supplier contract, including pricing, volume discounts and a confidentiality clause, into an unapproved AI assistant to ask "is anything risky in here?".
Information at risk	Confidential commercial terms of the supplier and the studio. Possibly personal data of named contacts.
What went wrong	The contract included a clause forbidding disclosure to third parties without consent. The manager was trying to be careful, and used the nearest tool. There was no approved alternative and no guidance.
Facts to establish	The wording of the confidentiality clause. The tool's plan and terms. Whether the conversation can be deleted, and whether it was used or shared. Whether the supplier would see this as a breach.
Immediate action	Delete the conversation, record what happened, check the clause and, where appropriate, tell the supplier. Consider legal advice if the clause carries penalties.
Lasting control	Add "contracts and NDAs" to the Amber list with a rule: check the confidentiality clause first, and use only an approved tool. Offer a safe route, such as asking AI about clause *types* in general rather than pasting the document.
Lesson	A ban without a safe alternative pushes people to the shadows. Give people a route that works.

Scenario 3: The performance records

Fictional recruitment agency, Fenwick Staffing

Heading	Detail
The situation	A manager pastes eighteen months of staff appraisal notes, sickness records and warnings into an AI tool and asks it to "rank who should be put on a performance plan".
Information at risk	Employee personal data, including absence reasons that may reveal health conditions; opinions about individuals.
What went wrong	Several problems at once: employee data in an unapproved tool; no transparency to staff that AI was used; and a request that amounts to profiling and ranking people, which may touch automated decision-making rules and, under the AI Act, may be a high-risk employment use.
Facts to establish	Whether a person would genuinely make the decision after reviewing it. What staff were told. The tool and its terms. Whether any decision has already been taken. The applicable employment law.
Immediate action	Stop. Do not act on the ranking. Delete the data from the tool where possible. Record what happened and speak to HR or an adviser before any action about any employee.
Lasting control	A policy rule: AI must not be used to decide, rank or score individual employees without prior approval, a risk assessment and a documented human decision-maker.
Lesson	Decisions about people carry legal and ethical weight. AI can help draft a fair process, but should not replace one.

Scenario 4: The passport photograph

Fictional online travel shop, Compass Ridge

Heading	Detail
The situation	A support agent receives a customer's passport photo to correct a name on a booking. To "read the name quickly", the agent uploads the image to an AI image tool on their phone.
Information at risk	Identity document data: full name, date of birth, nationality, document number, photograph.
What went wrong	The task did not need AI. The agent used a personal phone and a personal account. The passport image may now exist in a service with unknown retention. Identity documents are high-value for fraud.
Facts to establish	The tool's retention and sharing settings. Whether the image was stored. Whether the account was shared. Whether the customer's document was needed at all. Whether any misuse has occurred.
Immediate action	Delete the upload and conversation. Record details. Report internally the same day. Assess whether the risk to the customer is likely to be more than negligible. If so, take advice on notification, and consider telling the customer so that they can watch for misuse.
Lasting control	Identity documents go only into the secure verification system. A clear Red rule on ID documents. Company devices only for company data.
Lesson	When a task is small, the temptation to cut a corner is large. Red rules must be simple and known by heart.

Scenario 5: The key in the code

Fictional freelance developer, Tomas

Heading	Detail
The situation	A freelancer pastes a failing function into an AI coding assistant to find a bug. The snippet includes a live API key for a client's payment provider.
Information at risk	Credentials that unlock the client's payment account and customer records; confidential source code.
What went wrong	Secrets were hard-coded in the file. The freelancer used a personal account on a free plan. The key is now in an AI conversation history, and possibly in logs.
Facts to establish	The key's permissions. Whether it has been used by anyone else (check provider logs). The tool's terms. Whether the client's contract covers third-party tools.
Immediate action	**Revoke the key immediately** and issue a new one; check access logs for unusual use. Delete the conversation. Tell the client promptly. If personal data could have been reached, assess whether a breach occurred.
Lasting control	Keep secrets in environment variables or a secrets manager, never in code. Use a secrets scanner. Use an approved development tool. Add "never paste credentials" to the policy.
Lesson	Deleting the chat does not make a pasted key safe. **Rotate it.**

Scenario 6: The helpful support integration

Fictional online shop, Willow & Stone

Heading	Detail
The situation	The owner connects an AI assistant to the helpdesk and the order system so that it can draft replies automatically. It is given full read access for convenience.
Information at risk	Every customer's name, address, order and past conversation, including complaints that mention health, family and money.
What went wrong	Excessive access: the assistant could read far more than needed. A customer asked "why was I refused a refund?", and the assistant's draft quoted another customer's order number. The helpdesk's connector terms were never reviewed.
Facts to establish	What data the connector can read and write. The integration's terms and sub-processors. Whether any reply with another person's details was sent. Who approved the connection.
Immediate action	Disconnect the integration. Review sent messages for wrong disclosures. If a reply disclosed one customer's details to another, treat it as a possible personal data breach and assess it.
Lasting control	Least-privilege access, a test period with synthetic data, human approval of every reply, and logging. Change approval for any new integration.
Lesson	A connection is a decision about access. Make it on purpose, and as narrow as you can.

Scenario 7: The free tool and the financial statements

Fictional bakery group, Crumb & Co.

Heading	Detail
The situation	The finance manager uploads the unpublished year-end accounts and a five-year forecast to a free AI tool to produce a summary for the board.
Information at risk	Commercially sensitive financial information, plus salary details in a schedule.
What went wrong	She did not read the tool's terms. The free tier's terms allowed the provider to keep content and use it to improve services. The group has a lender covenant requiring confidentiality of forecasts.
Facts to establish	The tool's terms at the time of upload. The covenant wording. Whether the accounts are price-sensitive or will be filed soon. Whether salaries identified individuals.
Immediate action	Delete the upload and conversation, check for an opt-out setting, tell the finance director and review the covenant. If individual salaries were included, treat as personal data.
Lasting control	Approved finance tools with business terms. Prepare board summaries from figures without line-level detail. Keep a record of terms checked on a date.
Lesson	"Free" often means the terms favour the provider. Read the terms before the upload, not after.

Scenario 8: The browser extension with big permissions

Fictional accountancy practice, Marlow & Pike

Heading	Detail
The situation	An accountant installs a popular "AI summariser" browser extension. It asks to "read and change all your data on all websites", and she accepts.
Information at risk	Anything on a screen: client accounts, tax records, webmail, the practice-management system.
What went wrong	Nobody reviewed the extension. It sent page content to the extension's servers for processing. The vendor was a small company with no stated DPA.
Facts to establish	Which pages the extension saw, and when. The vendor's privacy terms. Whether content was stored. How many staff installed it.
Immediate action	Uninstall it from every browser. Review the extension's privacy information. Change passwords for any sessions open at the time. Assess whether client data was disclosed.
Lasting control	A list of approved extensions, managed browsers where possible, and a rule that any extension needing access to "all sites" needs approval.
Lesson	Extensions are software with a view of everything you do. They deserve the same scrutiny as any vendor.

Scenario 9: The AI report that said too much

Fictional consultancy, Brightwater Advisory

Heading	Detail
The situation	An analyst asks a connected AI assistant to "summarise our recent work for a new client proposal". The assistant draws on the shared drive and includes details of a competitor's project, including its name and budget.
Information at risk	Another client's confidential information and project details.
What went wrong	The assistant could read the whole drive, and the analyst did not read the output closely. The proposal was sent to the new client.
Facts to establish	Exactly what was disclosed and to whom. The confidentiality terms with the affected client. Whether the new client has since shared it.
Immediate action	Ask the recipient to delete the proposal and confirm in writing. Tell the affected client, with advice, if the contract requires it. Record the incident.
Lasting control	Restrict the assistant to specific folders. Add a human review step before external sending: check the output for names, numbers and details that should not be there.
Lesson	Output can leak what input never did. Read what the tool produced, not just what you asked for.

Scenario 10: The personal account on company work

Fictional software studio, Kestrel Digital

Heading	Detail
The situation	A developer routinely uses a personal AI account for work tasks because the company has no approved tool. After she leaves, the company asks for her conversation history. She says it contains project details, and the account is hers.
Information at risk	Project information and code snippets held in an account the company does not control.
What went wrong	There was no policy and no company accounts. The business cannot see, delete or recover information held in a personal account, and cannot demonstrate who has seen what.
Facts to establish	What was shared, over what period. The employment contract's confidentiality terms. The tool's terms for the account type. Whether other staff did the same.
Immediate action	Ask the former employee, in writing and courteously, to delete the relevant history and confirm. Review the contract. Do an inventory across the team.
Lasting control	Company-managed accounts for any approved tool, a written policy, and leaver steps that include AI tools.
Lesson	If the business cannot control the account, it cannot control the information in it.

Patterns across the ten cases

What the scenarios have in common

Pattern	Seen in scenarios	The control
No approved tool or no rule	1, 2, 7, 10	Approve tools, write rules
Sensitive data pasted for convenience	1, 3, 4, 5, 7	Green, Amber and Red; redaction; synthetic data
Excess access	6, 8, 9	Least privilege; approval for connections
Output not checked	6, 9	Human review before sending
Personal accounts or devices	4, 5, 10	Company accounts and devices
Unclear duties to clients or staff	1, 2, 3, 9	Check contracts; be transparent

What this means for your business

- Almost every case traces to a missing rule or tool, not to bad intent.
- The first response is containment and record-keeping, not blame.
- Each case needs facts established before any legal conclusion is drawn.
- A good control is cheap, simple and easy to follow.

GOOD PRACTICE **Chapter 6 action points**

Choose the three scenarios that look most like your business. For each, write one sentence: "If this happened here, the first thing we would do is..." Share the answers with the person who would be responsible.

RULES THAT WORK

CHAPTER

07

Build an AI Privacy Policy Your Employees Can Follow

How to set simple, workable rules for AI use, with a policy you can adapt in an afternoon.

IN THIS CHAPTER

- Why most AI policies fail, and what a usable one looks like
- The twelve decisions every small-business AI policy should make
- Who does what: owners, managers, administrators and staff
- A ready-to-adapt Small Business AI Acceptable Use Policy with placeholders

A policy is not a legal shield. It is a set of decisions, written down so that everyone makes the same ones. The test of a policy is simple: **can a new employee read it in ten minutes and know what to do on their first day?** If not, it will sit in a folder while people improvise.

Why policies fail

- **Too long.** Twenty pages of legalese are signed and never read.
- **Too vague.** "Use AI responsibly" tells nobody what to do at 4.45 pm on a Friday.
- **Too strict.** A blanket ban pushes use out of sight, onto personal accounts.
- **Out of date.** It names tools nobody uses and ignores the one everyone does.
- **Unowned.** Nobody is responsible for keeping it alive.

The twelve decisions

Whatever the size of your business, your policy needs to answer twelve questions. For a team of five to fifty, each answer can be a sentence or two.

1. **Who owns it?** One named person is accountable for AI and privacy decisions, even in a team of three.
2. **Which tools are approved, and for what?** A short list. Everything else is "not approved until reviewed".
3. **Which tools are prohibited?** Name them where there is a known problem, and say that personal accounts are not allowed for work.
4. **What may never be entered?** Your Red list: credentials, special-category data, identity documents and more.
5. **What needs conditions?** Your Amber list: minimise, redact, approved tool only, log the purpose.
6. **How are documents uploaded?** Check for hidden data, redact first, and never upload the only copy of anything.
7. **Who checks the output?** A person reads and takes responsibility before AI output is sent, published or acted on.
8. **What about decisions about people?** No solely automated decisions about customers, applicants or employees without approval and review.
9. **How long do we keep things?** Rules for chat history, saved outputs and deletion.
10. **What do people do if something goes wrong?** Report immediately, to a named person, without fear of blame.
11. **How do people learn the rules?** A short briefing when they join and a refresher each year.
12. **When do we review it?** A date in the calendar, and after any incident.

Approved and prohibited tools

Keep an **approved tools list** with the plan, the account type, the purpose and the data class allowed. Two columns make a start: *tool and plan*, and *what it may be used for*. Update it whenever a tool is added or removed. Include a rule that AI features switched on inside existing software, such as email, documents, design or accounting tools, need approval before first use, because they arrive by update.

Prohibit what you have reasons to prohibit: tools you have reviewed and rejected, personal accounts for work, unapproved extensions and anything that uses a "free" plan for personal data. Always combine a prohibition with a route: "if you need a tool we have not approved, ask [ROLE], who will reply within [TIME]".

Rules for personal data and confidential information

Anchor the policy in the Green, Amber and Red framework from Chapter 2. It is the part staff will remember. State clearly that the framework is an **internal control**, not a legal classification, and that a "Green" task does not remove the duty to think.

Rules for uploading documents

Uploads are a frequent route to exposure. The rule can be short: *before you upload, open the file, search it for names, numbers and hidden content, and ask whether the tool needs the whole file.* If in doubt, upload an extract or a redacted copy.

Employee and contractor responsibilities

Everyone who works for the business, including freelancers and temporary staff, follows the same rules. Contracts with contractors should say that they may use AI only in line with your policy and with client permissions, and that they must report incidents. Staff need to know that using a personal AI account for work breaks the policy even if their intentions are good.

Review and approval procedures

Make it easy to ask. A one-page **tool request** with five questions is enough: the tool and plan, the purpose, the data it will handle, who will use it and who will own it. The policy owner checks it against the ten-minute vendor check from Chapter 3 and records the decision and the date. If the tool will handle Amber data at scale or any special-category data, take the longer route in Chapter 4 and, where needed, advice.

Human verification of AI output

AI output can be wrong, biased, out of date, or contain content it should not. The rule: **a person must read, understand and take responsibility for any AI output before it is sent outside the business, published, stored as a record or used in a decision**. Review must be real: the reviewer must know enough to spot errors and have the authority to change the result. Provide a short review checklist; Resource 5 in Chapter 12 gives one.

Restrictions on automated decisions involving people

Decisions that affect people's jobs, pay, credit, access to services or reputation need special care in law (Art. 22 GDPR and, in some uses, the AI Act's rules for high-risk systems) [1][2]. A safe small-business rule: **AI may support a decision about an individual only with prior approval; a named human must make and be able to explain the decision; the individual must be able to ask for a human review.** Do not use AI to rank, score or screen people without taking advice.

Retention and deletion

Decide how long chat histories and saved outputs stay. For approved business tools, set the shortest retention that works, and delete outputs that contain personal data when the task is finished. Deleting a chat is not always the same as erasing every copy (Chapter 3), so the real protection is not putting sensitive data in.

Incident reporting

Staff must report any suspected exposure **immediately**, by a named route, and with no blame for honest reports. Chapter 9 provides the response procedure and form.

Training and review

New starters receive a short briefing within their first week. Everyone repeats it annually and after any major change. Keep a record of attendance. Chapter 12, Resource 9, is a training checklist. Under the EU AI Act, organisations that use AI systems have a duty relating to **AI literacy**, which Chapter 10 explains.

Responsibilities of managers and administrators

- **Owner or policy lead:** keeps the policy, approves tools, reviews incidents and sets the review date.
- **Managers:** make sure their teams know and follow the rules, and raise requests and concerns promptly.
- **Tool administrators:** configure approved tools to the settings the policy requires, manage accounts and leavers, and keep the inventory current.
- **Everyone:** follow the policy, check output, report incidents.

The sample policy

The policy below is **a template to adapt, not a legal document**. It uses **[SQUARE BRACKETS]** where you must insert your own details. Delete what you do not need and add what you do. Have it reviewed by an adviser if you handle sensitive data, work with clients who impose their own AI terms, or operate in a regulated sector.

> ABOUT THIS TEMPLATE **Small Business AI Acceptable Use Policy (template)**
>
> **[COMPANY NAME]** · Version [1.0] · Owner: [NAME AND ROLE] · Effective: [DATE] · Next review: [DATE]

1. Purpose and scope

This policy explains how [COMPANY NAME] uses artificial intelligence (AI) tools safely, protects the information entrusted to us, and meets our legal duties. It applies to all employees, contractors, freelancers and temporary workers using AI tools for [COMPANY NAME], on any device or account.

2. What we mean by AI tools

AI tools are services that generate or analyse text, images, audio, code or data, including chat assistants, writing and design tools, transcription services, AI features inside other software, browser extensions and plug-ins, and any tool that connects to our email, files or systems.

3. Approved and prohibited tools

- You may use only the tools on the **Approved Tools List** held at [LOCATION], and only for the purposes shown there.
- You must sign in with your company account. **Personal accounts must not be used for company work.**
- You must not install AI browser extensions, plug-ins or connectors, or switch on new AI features in existing software, without approval from [POLICY OWNER].
- To request a tool, send the Tool Request Form to [EMAIL OR CHANNEL]. We aim to reply within [NUMBER] working days.

4. Information you may and may not enter

We use three colours. They are an internal control, not a legal classification.

- **RED, never enter:** passwords, API keys and tokens; special-category data (health, ethnicity, beliefs, union membership, biometric, genetic, sex life); criminal-offence data; children's data; identity documents; full payment-card or bank details; privileged legal advice; anything an NDA or client contract forbids sharing with AI tools. [ADD YOUR OWN RED ITEMS.]
- **AMBER, only with conditions:** customer, client and employee personal data; contracts; unpublished financial data; source code; supplier terms. Use **approved tools only**, enter the **minimum necessary**, remove or replace identifying details where possible, and note the purpose. [ADD YOUR OWN AMBER ITEMS.]
- **GREEN, generally fine:** published material, public information, generic drafting, brainstorming and synthetic examples. Check that nothing sensitive is hidden in it.

If you are unsure which colour applies, treat it as Amber and ask [POLICY OWNER].

5. Uploading documents and files

Before uploading a file, open it, search it for names, numbers, hidden sheets, comments, tracked changes and metadata, and remove anything the task does not need. Never upload the only copy of a file. Do not upload customer lists, personnel files or client documents unless the tool is approved for that data class and, where we act as a processor, the client has permitted it.

6. Checking AI output

You are responsible for anything you send, publish or store that was produced with AI. Read all of it. Check facts, figures, names and references. Check that it contains no confidential or personal information that should not be there. Do not present AI-generated content as the work of a named person where that would mislead. Never rely on AI for legal, medical, financial or safety-critical conclusions without qualified review.

7. Decisions about people

AI must not be used on its own to make, or to recommend in a way that is effectively decisive, any decision about an employee, applicant, customer or other individual, including hiring, discipline, pay, credit, access to services or termination. Any proposal to use AI to support such a decision needs prior written approval from [POLICY OWNER], a risk assessment, and a named person who makes and can explain the decision.

8. Transparency

Where AI tools are used in ways that affect customers or staff, we will say so in our privacy notices and, where required, at the point of interaction. If you build or deploy a chatbot or any tool that interacts directly with people, tell [POLICY OWNER] first.

9. Retention and deletion

Chat history and saved outputs in approved tools are kept for no more than [NUMBER] days unless a record is required. Delete outputs containing personal data when the task is finished. Do not store AI output containing personal data in personal files or personal cloud storage.

10. Reporting incidents

If you think you have put information into an AI tool that you should not have, or you notice any other AI-related exposure, **tell [NAME / EMAIL / PHONE] immediately**, and write down what happened and when. Do not delete evidence and do not try to fix it alone. Honest, prompt reports will not result in disciplinary action for the report itself. [ADD YOUR OWN WORDING ON DISCIPLINARY MATTERS WITH ADVICE.]

11. Contractors and freelancers

Contractors must follow this policy, must use only tools permitted by their engagement terms and our clients' instructions, and must report incidents within [NUMBER] hours of becoming aware of them.

12. Training and review

Everyone using AI tools for [COMPANY NAME] completes the AI briefing within [NUMBER] days of starting and each [YEAR/PERIOD]. [POLICY OWNER] reviews this policy at least every [SIX/TWELVE] months and after any significant incident, law change or new tool.

13. Breaches of this policy

Failure to follow this policy may lead to action under [DISCIPLINARY PROCEDURE / CONTRACT TERMS]. Questions about this policy should go to [POLICY OWNER].

14. Acknowledgement

I have read and understood this policy. Name: [____] Signature: [____] Date: [____]

SOURCE NOTE **Professional review may be needed**

A sample policy is a starting point. Take advice on the parts that depend on employment law in your country, your sector rules, your client contracts and your use of employee or special-category data.

What this means for your business

- A usable policy is short, specific, owned and reviewed.
- Pair every prohibition with a route that works.
- Decisions about people need approval, a human decision-maker and a right to review.
- A policy is only as effective as the briefing that goes with it.

GOOD PRACTICE **Chapter 7 action points**

Copy the sample policy, fill the brackets, cut anything you do not need, and ask three colleagues to read it in ten minutes. Fix whatever they find confusing. Adopt it on a date and put the review date in your calendar.

PUTTING IT TO WORK

CHAPTER

08

AI in Marketing, HR, Customer Service, Finance and Software

Eight business functions, each with its common risks, safer workflows, approval questions and tasks that need no real data.

IN THIS CHAPTER

- Common risks and safer workflows for eight business functions
- The approval questions to ask before each use
- Tasks that can often be done with synthetic, public or minimised data
- When a use is sensitive enough to need extra review

The earlier chapters gave you principles. This one applies them. For each function you will find the usual risks, a safer way of working, the questions an approver should ask, and tasks that can often be done without real personal data at all. Each section ends with a signal: **proceed**, **proceed with safeguards** or **stop and take advice**.

> WATCH OUT **High-impact uses need more**
>
> Where AI touches hiring, pay, credit, health, children, monitoring or any decision about a person, additional legal, security or professional review may be required, whatever the tool. Treat the sections on HR and healthcare-adjacent services accordingly.

Marketing and lead generation

Common risks: uploading customer or prospect lists; using purchased or scraped lists; profiling people for targeting; using testimonials or photos without permission; making unsupported claims in AI-written copy; breaching e-marketing rules (consent for email and text marketing under the ePrivacy rules, and in the UK the Privacy and Electronic Communications Regulations) [22].

Safer workflow: use AI for copy, ideas, subject lines, calendars and structure, working from product facts and public information. Segment lists in your own systems, not in a chat tool. Where you must analyse customer data, use aggregated or pseudonymised extracts in an approved business tool.

- **Approval questions:** Does it use personal data? Do people expect it? Is consent or another basis in place for the channel? Who checks every claim?
- **Often possible without real data:** campaign concepts, blog drafts, ad variants, content calendars, persona sketches built from public research, subject-line tests.

Signal: Green for drafting; Amber for any list analysis; Red for sending customer lists to unapproved tools.

E-commerce and online customer support

Common risks: pasting tickets with addresses, order details and health remarks; connecting an assistant to the helpdesk with broad access; chatbots that give wrong answers about returns, pricing or rights; failure to tell customers they are speaking to AI.

Safer workflow: start with **drafting assistance** where a person reviews each reply. Prepare templates with placeholders. Scope any integration to the minimum fields. Test with synthetic tickets. Keep a human escalation route. If you launch a customer-facing chatbot, tell customers it is AI, which the EU AI Act's transparency rules require for many such systems from 2 August 2026 [2][3].

- **Approval questions:** What fields can the assistant read and write? What is the escalation route? Who reviews wrong answers? Is the tool's DPA in place? Have we told customers?
- **Often possible without real data:** reply templates, FAQ drafts, tone guides, return-policy wording, themes drawn from redacted samples.

Signal: proceed with safeguards for drafting; stop and review before giving any tool autonomous access to customers' accounts or payments.

Human resources and recruitment

Common risks: pasting CVs, appraisals, grievances or sickness records; using AI to screen, rank or score candidates or staff; hidden bias in outputs; monitoring employees; special-category data in free text; power imbalance undermining consent. Under the EU AI Act, AI systems used for recruitment, selection, evaluation, task allocation or monitoring of workers are listed as **high-risk** in Annex III, and emotion recognition in the workplace is prohibited in most cases [2][3].

Safer workflow: use AI for job-ad drafts, interview question banks, policy templates and training outlines, with no real candidate or employee data. For any use that touches individuals, involve an adviser first. Tell candidates and staff how AI is used, and keep a human decision-maker who can explain each outcome.

- **Approval questions:** Does the system evaluate or rank individuals? What are the data and the lawful basis? Is there a risk assessment? Who decides, and can they explain? Is employment law or a works-council process involved?
- **Often possible without real data:** job descriptions, onboarding checklists, policy drafts, generic interview guides, training materials.

Signal: proceed for template work; **stop and take advice** for screening, scoring, monitoring or any decision about an individual.

Finance and accounting

Common risks: uploading unpublished accounts, forecasts, payroll, bank statements or invoices with personal details; trusting AI arithmetic or tax statements; exposing banking credentials; confidentiality duties to lenders and clients.

Safer workflow: use AI to explain concepts, draft finance policies, build spreadsheet formulas on dummy data, and prepare board-paper structures. Keep account numbers, payroll and bank details out. Check every figure against source records. Do not use AI as the final authority on tax or accounting treatment.

- **Approval questions:** Is any individual identifiable (salaries, suppliers who are sole traders)? Do lender or client agreements restrict disclosure? Who reconciles the numbers?
- **Often possible without real data:** formula help, templates, process maps, variance-analysis layouts, explanations of terms.

Signal: Green for explanation; Amber for aggregated figures in approved tools; Red for credentials and payroll detail.

Legal and contract review

Common risks: uploading contracts under NDA; sharing privileged advice; relying on AI statements about the law, including citations that do not exist; treating a summary as advice.

Safer workflow: use AI to explain a clause type, draft a checklist of questions for your lawyer, or structure a plain-language summary of your own template. Do not paste confidential agreements unless the contract permits it and the tool is approved. **Never rely on an AI-generated legal citation without checking it in an official source.**

- **Approval questions:** Does the confidentiality clause allow third-party tools? Is the tool approved? Who with legal qualifications will review the result?
- **Often possible without real data:** glossaries, generic clause explanations, issue lists, templates to be reviewed by a lawyer.

Signal: proceed for explanation; proceed with safeguards for your own templates; stop for third-party confidential agreements without permission.

Software development

Common risks: secrets in code; proprietary code in unapproved tools; real customer data in test sets; AI-generated code with vulnerabilities or licence problems; connecting an assistant to repositories with wider access than needed; dependency on code nobody understands.

Safer workflow: approve a specific coding assistant with documented data terms. Keep secrets in a secrets manager and run secret scanning. Use synthetic test data. Review all generated code like any contribution, with tests. Scope repository access.

- **Approval questions:** Does the tool store or learn from code? What can it access? Where are secrets kept? Who reviews generated code? What are the licence terms for outputs?
- **Often possible without real data:** boilerplate, unit tests on synthetic data, documentation, refactoring suggestions on non-sensitive modules, explaining error messages with secrets removed.

Signal: proceed with safeguards; stop if credentials or real customer data are in the context.

Consultants and freelancers

Common risks: client material pasted into personal accounts; breach of engagement confidentiality; no clear processor role; mixing clients' information in one chat history; leaving access open after a project.

Safer workflow: put an **AI clause** in every engagement letter: which tools may be used, for what, and with what data. Keep separate workspaces per client. Use business-tier accounts. Delete project material at the end, and say so in your close-out note.

- **Approval questions:** Does the client contract allow the tool? Am I a processor? What do I tell the client? How will I delete the material?
- **Often possible without real data:** proposals from your own templates, frameworks, research from public sources, meeting-agenda drafts.

Signal: proceed with safeguards once client permission is documented.

Healthcare-adjacent services

Examples: physiotherapy, counselling, coaching, fitness, pharmacies, care homes, insurance intermediaries, wellness apps, medical-device distributors. These businesses may handle **health data**, which is special-category data under Art. 9 and often subject to additional national rules and professional duties [1].

Common risks: pasting notes, appointment details or messages that reveal a condition; transcribing consultations with general tools; profiling clients; relying on AI for clinical judgment.

Safer workflow: keep general AI tools away from client or patient information. Use AI only for non-clinical admin on synthetic or public content: newsletters, website copy, policy templates, scheduling wording. Any tool that touches health data should be assessed first, including a DPIA and a specific Art. 9 condition, with specialist advice.

- **Approval questions:** Is health data involved? Which Art. 9 condition applies? Is a DPIA complete? Are professional confidentiality rules engaged? Who is the regulator?
- **Often possible without real data:** marketing copy, general educational leaflets (reviewed by a professional), appointment-reminder wording, staff rota templates.

Signal: stop and take advice before using any AI tool with real client or patient information.

One table for all eight

Function by function: the default position

Function	Typical safe use	Needs approval	Needs advice
Marketing	Drafting copy and ideas	List analysis; segmentation	Profiling; scraped or bought data
E-commerce support	Reply templates; FAQs	Connecting to helpdesk	Autonomous actions on accounts
HR and recruitment	Job ads; policy drafts	Any real employee data	Screening, scoring, monitoring
Finance	Formulas; explanations	Aggregated figures	Payroll and bank detail
Legal	Clause explanations	Your own templates	Third-party confidential contracts
Software	Boilerplate; tests on synthetic data	Repository access	Real customer data in context
Consultants and freelancers	Proposals; frameworks	Client material	Client special-category data
Healthcare-adjacent	Non-clinical admin copy	Anything involving individuals	Any health data

What this means for your business

- Every function has safe, productive uses that need no real personal data.
- Approval questions turn a worry into a check.
- High-impact uses, especially in HR and health, call for advice first.

GOOD PRACTICE **Chapter 8 action points**

For each function in your business, write down three tasks AI can do with no real data and one task that is off limits. Add them to your policy as examples. Review the list with the person who does the work.

WHEN IT HAPPENS

CHAPTER

09

What to Do If You Have Already Shared Sensitive Information

A calm, ten-step response guide, a decision tree and a ready-to-use incident report form.

IN THIS CHAPTER

- Ten steps from "stop" to "improve", in the order that works
- Why an accidental upload is not automatically a reportable breach
- How the GDPR's 72-hour rule works, and when it does not apply
- When to bring in qualified advice
- An AI Data Exposure Incident Report Form

Sooner or later someone in almost every business pastes something they should not have. What matters is what happens in the next hour. A calm, orderly response usually reduces the harm. A panicked one can add to it: deleting evidence, telling no one, or telling everyone. This chapter gives you a plan to follow when your pulse is high.

IN PLAIN ENGLISH **Three things to hold on to**

Do not panic. Many exposures turn out to be low-risk, and all are easier to handle if found early. **Do not hide it.** Delay and silence are what make incidents worse. **Do not decide alone.** Involve the named person, and advice where the checklist below says so.

The ten steps at a glance

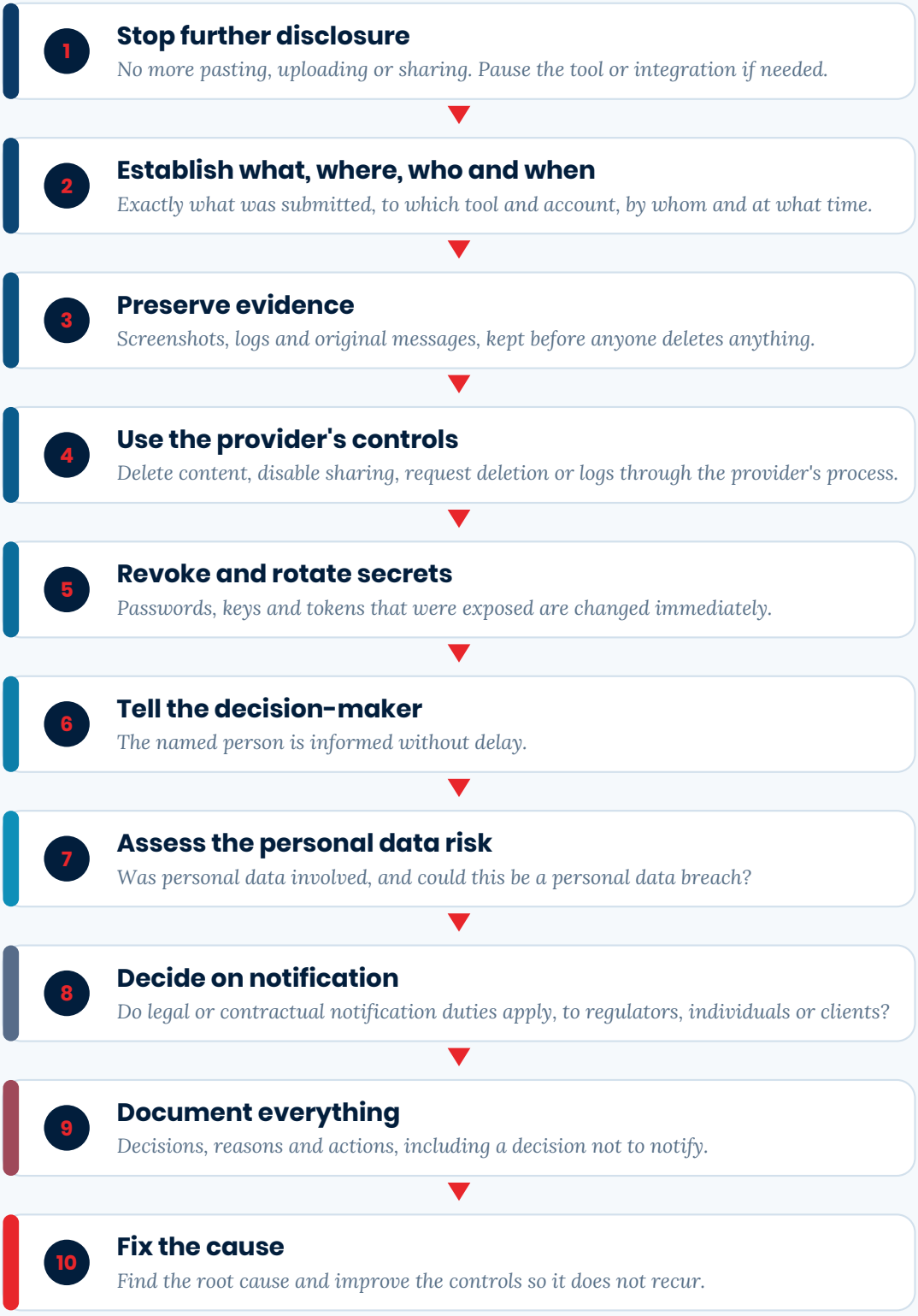


Figure 14 From discovery to improvement

Step 1: Stop further disclosure

Ask the person to stop using the tool for that task. If a shared link exists, disable it. If the tool is connected to company systems, disconnect it or revoke its access until you understand what it could reach. Be matter-of-fact. The aim is to prevent the situation growing, not to find fault.

Step 2: Identify exactly what was submitted

Write down: **what** (the type of information and, as far as you can tell, whose), **where** (tool, plan, account, any shared workspace), **who** submitted it, **when** and **how many people** it concerns. Ask the person to show you the conversation rather than relying on memory. Note whether special-category data, financial details, identity documents, children's data or credentials were involved. This step drives every decision after it, so take a few minutes over it.

Step 3: Preserve evidence and records

Take screenshots of the conversation, the settings page and the account details. Export logs where available. Keep the original files. Do **not** delete the conversation yet if that would destroy the only record, though in practice a screenshot or export first and then deletion is usually the right order. Record the date and time you discovered the issue, because it may matter for the notification clock, as explained below.

Step 4: Review the provider's controls and requests

Check what the tool lets you do: delete the conversation or file, turn off history or sharing, view audit logs, and submit a data deletion or access request. Read the provider's help pages or contact business support if you are on a business plan. Ask specifically: *Was the content retained? Was it used for training or reviewed by anyone? Can you confirm deletion, and from which systems? Were there access events from outside our account?* Remember that deleting a chat may not remove every copy at once, and that you should record the provider's answers with dates.

Step 5: Revoke exposed credentials and rotate secrets

If any password, API key, token, certificate or connection string went into the tool, **treat it as compromised**. Revoke or change it immediately, check the provider's access logs for unfamiliar use, and note the time you rotated it. This step does not wait for the rest of the assessment. A secret is a key, and anybody holding a copy can use it.

Step 6: Tell the right internal decision-maker

Inform the person named in your policy within the hour: the owner, the policy lead or the data protection contact. If you work for a client as a processor, check your contract: you may have a duty to tell them **without undue delay**. Tell your insurer if your policy requires early notice.

Step 7: Assess whether personal data was compromised

Ask whether the information included personal data and, if so, whether the event is a **personal data breach**, which the GDPR defines as a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data (Art. 4(12)) [1]. This is where careful thinking pays off, because the answer is not automatic.

> **WHAT THE LAW SAYS** **An accidental upload is not automatically a reportable breach**
>
> Putting personal data into an AI tool is not, in itself, a breach. It may be perfectly lawful if you have a lawful basis, a DPA, a suitable tool and transparency. It may be an **unauthorised disclosure** if the tool was unapproved, no contract existed, the data was sent to someone who should not have it, or it was exposed to others. And even if it is a breach, it is **reportable to the regulator** only if it is **likely to result in a risk to people's rights and freedoms**. The facts decide.

Useful questions to ask, drawn from the EDPB's breach guidelines [6]:

- **What type of breach is it?** Confidentiality (someone saw it), integrity (it was changed) or availability (it was lost).
- **How sensitive is the data?** Special-category data, financial details, identity documents and credentials raise the risk.
- **How easy is it to identify people?** Names and contact details identify directly.
- **How severe could the consequences be?** Fraud, discrimination, embarrassment, loss of confidentiality, harm to vulnerable people.
- **How many people are affected, and are any vulnerable?** Children, patients and employees need extra care.
- **Who may have seen it?** A reputable processor under a DPA is different from an unknown party, a public link or an attacker.
- **Can the damage be reduced?** Prompt deletion, confirmed non-access and rotated credentials reduce risk.

Step 8: Determine whether notification applies

Supervisory authority. If a personal data breach has occurred, Art. 33 requires the **controller** to notify the supervisory authority **without undue delay and, where feasible, not later than 72 hours after having become aware of it**, unless the breach is **unlikely to result in a risk** to the rights and freedoms of individuals [1][6]. When notification is not made within 72 hours, it must be accompanied by reasons for the delay. Information may be provided in phases (Art. 33(4)).

Accuracy matters here. The 72-hour period:

- applies only where there is a **personal data breach** and the **risk threshold** is met;
- applies to the **controller**, and starts when the controller becomes **aware** of the breach, which the EDPB describes as having a reasonable degree of certainty that a security incident has occurred that has compromised personal data [6];
- is **not** a universal deadline for every AI mistake;
- is easiest to defend if you write down the time of discovery, the time you reached reasonable certainty, and why.

Individuals. Art. 34 requires you to communicate the breach to affected individuals **without undue delay** where it is **likely to result in a high risk** to them, with exceptions such as effective encryption or measures that make the high risk no longer likely [1].

Processors. A processor must notify the controller **without undue delay** after becoming aware of a breach (Art. 33(2)). If you are a processor for a client, your contract and the GDPR both point to telling them quickly.

Other duties. Contracts, insurance policies, sector rules and card-payment rules may have their own notification triggers. In the UK, the same 72-hour rule applies to reporting to the ICO under the UK GDPR [15][16]. Whatever the answer, Art. 33(5) requires you to **document every personal data breach**, including its effects and the action taken, whether or not you notify.

1	**Is personal data, confidential information or a secret involved?**	**YES** Go to question 2.	**NO** Record it as an ordinary issue and fix the cause.
2	**Could it have been seen or used by someone who should not have access?**	**YES** Go to question 3.	**NO** Record it, contain it and keep notes. Check again whether access was possible.
3	**Does it involve special-category, financial, identity or children's data, credentials, or many people?**	**YES** Escalate now to the owner and a specialist. Aim to decide on notification within hours.	**NO** Go to question 4.
4	**Is there a likely risk to individuals, for example contact details with unknown recipients?**	**YES** Escalate to the owner. The 72-hour authority notification may apply.	**NO** Record why a risk is unlikely, and keep that note.
5	**Are you processing this data for a client?**	**YES** Tell the client without undue delay, as your contract and Art. 33(2) require.	**NO** Continue your own assessment.

Figure 15 Does this incident need to be escalated now?

WATCH OUT **When to bring in qualified advice**

Get legal or data protection advice promptly when the incident may involve **significant volumes of personal data**, **special-category data**, **children's data**, **credentials** that could reach other systems, **a large number of people**, a client's data, or any doubt about the notification decision. A short call early is cheaper than a long correction later.

Step 9: Document decisions and actions

Record what you found, what you decided and why, who you spoke to, and when. A decision **not** to notify is still a decision that needs a recorded reason. If a regulator later asks, the quality of your record is part of the answer.

Step 10: Review the root cause and improve

When the dust settles, ask *why did it happen*? Not "who did it?" Typical root causes are no approved tool, no rule, unclear guidance, time pressure, or a setting nobody had checked. Choose one or two **changes**: a rule, a setting, a training session, a template. Tell staff what you learned, without naming individuals. Update the policy, the inventory and the risk register. A business that learns visibly gets better quickly.

A worked timeline

The following fictional timeline shows how a small business might handle the first working day. It is illustrative and not a template for what a regulator would require in any case.

09:10 — **Discovery**
A colleague reports that a customer spreadsheet was uploaded to a free AI tool yesterday. The reporter writes down the time.

09:30 — **Containment**
The person stops using the tool. The shared link, if any, is disabled.

09:45 — **Evidence**
Screenshots of the conversation and settings are saved. The file name, columns and row count are recorded.

10:30 — **Provider controls**
The conversation is exported then deleted. A support request asks about retention and access logs.

11:00 — **Escalation**
The owner is told. The data was names, emails and order numbers for 1,400 customers, no payment or special-category data.

13:00 — **Assessment**
The tool's terms are read. Risk to individuals is assessed as low but not negligible. An adviser is called.

15:00 — **Decision**
After advice, the business records that it will not notify the authority, with reasons, and will tell the affected client because the contract requires it.

Next week — **Follow-up**
Policy updated, approved tool provided, staff briefed.

Figure 16 An illustrative first working day

AI Data Exposure Incident Report Form

TEMPLATE

AI data exposure incident report

Complete as soon as an incident is reported. Keep the original, even if you decide not to notify. This is a template and not legal advice.

Report number, date and time reported, and by whom

Date and time the incident was discovered (and by whom)

What happened, in plain words

AI tool, plan and account type (business or personal)

Who submitted the information, and when

Type of information involved (tick in your head: personal data, special-category, financial, credentials, confidential business, source code, other)

People affected: categories and approximate numbers (customers, staff, children, others)

Was the information shared, made public or accessible to others? How do we know?

Containment actions taken, with times

Provider controls used and provider's responses (deletion, logs, retention, training)

Credentials or secrets exposed, and when they were revoked or rotated

Likely consequences for individuals (likelihood and severity)

Is it a personal data breach? Reasons for our view

Time we became aware (reasonable certainty)

Notification decisions: authority, individuals, client, insurer, others, with reasons and times

Advice taken (from whom and when)

Root cause

Corrective and preventive actions, owners and dates

Review date and sign-off

What this means for your business

- Stop, record, preserve, use the provider's controls, and rotate any secret.
- An accidental upload is not automatically a reportable breach. Assess the facts.
- The 72-hour rule applies to personal data breaches that meet the risk test, from the point of awareness.
- Document every decision, including a decision not to notify.
- Fix the cause. Do not just fix the person.

GOOD PRACTICE **Chapter 9 action points**

Name your incident contact and put their details in the policy. Print the form and keep a copy where staff can find it. Run a 20-minute rehearsal with one scenario from Chapter 6.

WHAT IS COMING

CHAPTER

10

The EU AI Act and the Future of Business Privacy

What the AI Act actually asks of a business that uses AI tools, in proportion.

IN THIS CHAPTER

- How the Act sorts AI into risk levels
- What is prohibited, what is high-risk and what is only a transparency matter
- AI literacy, and the difference between a provider and a deployer
- How the Act sits alongside the GDPR
- A checklist for deciding when to take specialist advice

The EU AI Act (Regulation (EU) 2024/1689) is the world's first comprehensive law on artificial intelligence [2]. Headlines make it sound as though every business using ChatGPT faces a mountain of paperwork. It does not. The Act is built on **proportion**: most obligations fall on those who develop AI or use it for high-impact purposes. This chapter explains the parts a small business using AI tools needs to understand, and avoids presenting every business as subject to the same rules.

WATCH OUT **Dates and details to verify**

The Act was amended in July 2026 by Regulation (EU) 2026/1744, often called the AI Omnibus, which postponed several deadlines [3]. The dates and wording in this chapter were checked against the Official Journal text of Regulation (EU) 2026/1744 and the original Regulation on EUR-Lex on 24 October 2026. EU law is amended and guidance is issued regularly, so **re-check the current consolidated text on EUR-Lex before you rely on a date**.

A risk-based structure

The Act sorts AI into levels, and the rules rise with the risk.

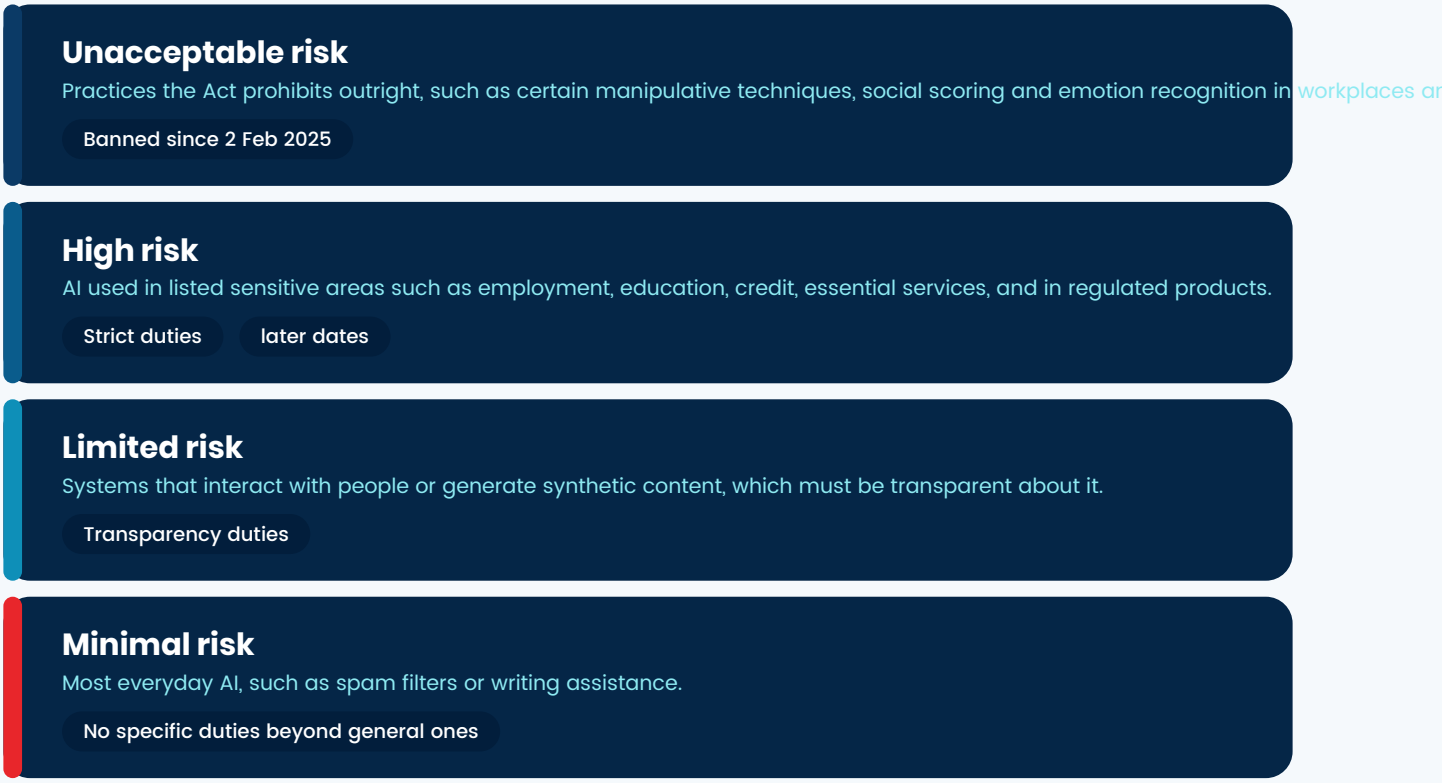


Figure 17 The Act's four levels, simplified

Separately, the Act regulates **general-purpose AI models**, the foundation models behind assistants. Those duties fall mainly on the companies that provide the models, from 2 August 2025, not on a business using an assistant to draft emails.

Prohibited practices

Article 5 prohibits a list of practices, applying since 2 February 2025 [2]. They include AI that deploys subliminal or purposefully manipulative techniques causing significant harm; exploits vulnerabilities due to age, disability or social situation; scores people on social behaviour in ways that lead to unjustified detrimental treatment; predicts the risk of someone committing a crime solely from profiling; builds facial-recognition databases by untargeted scraping; infers emotions in workplaces or education except for medical or safety reasons; and certain biometric categorisation and real-time remote biometric identification uses. A small business using ordinary AI tools is unlikely to be near these lines, but **emotion analysis of staff or customers, covert scoring and scraping faces are the ones to be wary of**. The 2026 amendment adds two prohibitions, applying from **2 December 2026**: placing on the market or using an AI system that generates or manipulates realistic intimate images or sexually explicit material of an identifiable person without their explicit consent, and systems that generate child sexual abuse material. For systems not designed for that purpose, the ban applies where abuse is a reasonably foreseeable outcome and reasonable safeguards are missing [3].

High-risk AI systems

Article 6 and the annexes define high-risk systems in two groups: AI embedded in products already regulated for safety (Annex I), and stand-alone systems in listed areas (Annex III), including **employment and worker management** (recruitment, selection, evaluation, promotion, task allocation, monitoring), education, access to essential private services such as **credit scoring**, and biometrics, among others [2].

High-risk systems face obligations for risk management, data quality, documentation, human oversight, accuracy and security. **Providers** carry most of them. **Deployers**, the businesses that use such systems, have their own duties under Art. 26, including using the system according to instructions, assigning competent human oversight, monitoring operation, keeping logs they control, and informing workers' representatives and affected people where required [2]. Regulation (EU) 2026/1744 postponed the high-risk rules to **2 December 2027** for Annex III stand-alone systems and **2 August 2028** for Annex I products [3].

> **IN PLAIN ENGLISH** **The HR example**
>
> A small employer that buys an AI tool to screen job applicants would be a **deployer of a high-risk system**, even though it did not build anything. This is why Chapter 8 says "stop and take advice" for screening and scoring.

Transparency duties

Article 50 sets transparency rules for certain systems. They apply from **2 August 2026**, with a transition to 2 December 2026 for providers whose generative systems were already on the market and must add machine-readable marking [2][3]. In summary:

- Providers must design systems that interact directly with people so that people are **told they are dealing with AI**, unless obvious.
- Providers of systems that generate synthetic audio, image, video or text must ensure outputs are **marked in a machine-readable way** where applicable.
- Deployers of **deepfakes** must disclose that content is artificially generated or manipulated, and deployers of **emotion recognition or biometric categorisation** systems must inform the people exposed.
- Deployers publishing **AI-generated text to inform the public on matters of public interest** must disclose it, unless it has undergone human review and someone holds editorial responsibility.

For a small business, the clearest practical consequence is simple: **if you put a chatbot or voice agent in front of customers, tell them it is AI.** If you publish AI-generated images that look real, consider labelling them.

AI literacy

Article 4 has applied since 2 February 2025. As amended in 2026, it requires providers and deployers to **take measures to support the development of AI literacy** among their staff and others who use AI on their behalf, taking account of their knowledge, experience, training and the context of use. It does **not** require a business to guarantee any specific level of literacy for any individual, and the Commission and Member States are to support SMEs in meeting it [2][3]. The earlier wording, in force from 2025 to July 2026, asked for measures "to ensure, to their best extent, a sufficient level" of literacy. In either form, the approach is the same: proportionate training that fits the role. A short briefing on this book's rules, repeated each year, with a record of attendance, is a sensible foundation. The Act does not name a particular course.

Providers and deployers

Provider and deployer in plain English

Role	Meaning (simplified, Art. 3)	Small-business example
Provider	Develops an AI system or model, or has one developed, and places it on the market or puts it into service under its own name or trade mark.	A software company that builds an AI recruitment tool and sells it.
Deployer	Uses an AI system under its own authority in a professional capacity.	A shop that uses a chatbot product on its website, or an employer that uses a screening tool.
Importer, distributor	Brings in or supplies AI systems from elsewhere.	A reseller of a non-EU AI product.

A deployer can **become a provider** by putting its own name or trade mark on a high-risk system, making a substantial modification, or changing a system's purpose so that it becomes high-risk (Art. 25) [2]. A business that merely uses an assistant to draft text is a deployer of a general tool, subject mainly to AI literacy and, where relevant, transparency duties.

How the AI Act and the GDPR work together

The AI Act **does not replace the GDPR**. It states that it is without prejudice to EU data protection law (Art. 2(7)), and a system can be subject to both [2]. If an AI system processes personal data, you still need a lawful basis, transparency, security, a DPA, and a DPIA where required. In some cases the Act helps: deployers of certain high-risk systems must use the provider's information when carrying out a DPIA (Art. 26(9)). Do not treat one regime as ticking the box for the other.

Why obligations depend on role, system, use and date

Four questions decide what applies to you:

1. **What is our role?** Provider, deployer, importer, distributor, or only a user of a general tool?
2. **What is the system?** Is it a general assistant, a stand-alone system for a listed purpose, or a component of a regulated product?
3. **What is the use?** Drafting copy is different from screening applicants or scoring creditworthiness.
4. **What is the date?** Some obligations already apply; others, such as those for high-risk systems, have been postponed. Check the current dates.

1 Aug 2024 — **Entry into force**
The Act enters into force; obligations phase in.

2 Feb 2025 — **Prohibitions and AI literacy**
Chapter I and the prohibited practices in Art. 5 apply, including the AI literacy duty in Art. 4.

2 Aug 2025 — **General-purpose AI**
Duties for providers of general-purpose AI models, governance and most penalty provisions apply.

2 Aug 2026 — **Transparency**
Article 50 transparency duties apply. Providers of generative systems placed on the market before this date have until 2 Dec 2026 to comply with the machine-readable marking duty in Art. 50(2).

2 Dec 2026 — **New prohibitions**
The added prohibitions on non-consensual intimate-image and child-abuse-material generation apply.

2 Dec 2027 — **Stand-alone high-risk**
Annex III high-risk obligations apply (postponed from 2 Aug 2026).

2 Aug 2028 — **Product-embedded high-risk**
Obligations for high-risk AI in regulated products apply (postponed from 2 Aug 2027).

Figure 18 AI Act timeline as amended by Regulation (EU) 2026/1744 (verify on EUR-Lex)

Penalties, in proportion

The Act allows administrative fines of up to EUR 35 million or 7% of worldwide annual turnover for prohibited practices, and lower maximums for other infringements; for SMEs, including start-ups, the lower of the two amounts applies, and the 2026 amendment extends the same rule to small mid-cap companies (Art. 99) [2][3]. These are ceilings. Actual penalties depend on the circumstances and on national implementation. The more useful message for a small business is that **the obligations are manageable if you know which of them are yours**.

What about the UK?

The UK has no equivalent of the AI Act. UK businesses are governed by existing law, including the UK GDPR, equality law and sector regulators, and the ICO's guidance [14]. But a UK business may still fall within the EU Act if it places AI systems on the EU market or its AI system's output is used in the EU. Check your position if you sell into the EU.

When to seek specialist advice

AI ACT: WHEN SHOULD WE TAKE SPECIALIST ADVICE? (TICK ANY THAT APPLY)

- ☐ We use, or plan to use, AI to screen, rank, evaluate or monitor job applicants or staff.
- ☐ We use AI in decisions about credit, insurance, education or access to services.
- ☐ We use AI to infer emotions or to categorise people by biometric data.
- ☐ We build, brand or sell an AI system, or substantially modify one.
- ☐ We provide an AI system to customers that others will use.
- ☐ We run a chatbot or voice agent that talks to the public and we have not told people it is AI.
- ☐ We publish AI-generated images, audio or video that could pass as real.
- ☐ We sell AI-related products into the EU from outside it, or the reverse.
- ☐ We cannot say whether we are a provider or a deployer for one of our tools.

0 ticks	1 or 2 ticks	3 or more ticks
Unlikely to be affected beyond literacy and basics Keep your inventory, train your people, review each quarter.	**Worth a specialist conversation** Ask an adviser to confirm your role and any dates that apply.	**Take advice before proceeding** Obligations may be substantial. Do not launch or expand until clear.

Figure 19 How to read the result

What this means for your business

- The AI Act is proportionate. Most small-business use is low risk.
- Role, system, use and date decide the duties. Do not assume they all apply.
- Telling people when they are talking to AI, and training staff, are the common minimum steps.
- HR, credit and similar uses can be high-risk: take advice.
- It adds to the GDPR. It does not replace it.

GOOD PRACTICE **Chapter 10 action points**

List every AI system you use and mark whether you are a provider or a deployer. Tick the checklist above. If you run a customer chatbot, make sure it says it is AI. Put "verify AI Act dates" in your calendar for each quarter.

THE PLAN

CHAPTER

11

The 30-Day AI Privacy Protection Plan

A realistic four-week roadmap that fits around a working week: discover, assess, protect, verify.

IN THIS CHAPTER

- A day-by-day plan in four weeks: Discover, Assess, Protect, Verify
- Priority tags so you can start with the urgent items if time is short
- A responsibility table and a 30-day progress tracker
- A printable checklist for the whole plan

Most plans fail because they are too large. This one asks for **15 to 60 minutes a day**, one task at a time, in the order that gives the most protection first. Each task has a priority tag: **[URGENT]** closes a likely gap, **[CORE]** builds the system, **[LATER]** makes it durable. If you only have time for the urgent tasks, do those first.

IN PLAIN ENGLISH **How to use this chapter**

Put the dates in your calendar today. Mark each day done on the tracker at the end. If you miss a day, do not restart: carry on and catch up at the weekend. Where a task points to a resource, you will find it in Chapter 12.



WEEK 1

Discover: find out what is actually in use

You cannot manage what you cannot see. This week is about finding every tool, account and use, including the ones staff chose themselves.

DAY 1

[URGENT] Name an owner

Task: appoint one person accountable for AI and privacy decisions. **Why:** decisions need an owner before they become urgent. **Time:** 15 min. **Role:** Owner. **Deliverable:** a named owner and a one-line mandate. **Done when:** the name is written on the inventory and the team has been told.

☐ DONE

DAY 2

[URGENT] Ask what people use

Task: ask everyone which AI tools they use for work, including free accounts, phone apps and extensions. Say clearly that honest answers will not be punished. **Why:** hidden use is the biggest gap. **Time:** 30 min. **Role:** Owner. **Deliverable:** a raw list of tools and users. **Done when:** every person has answered.

☐ DONE

DAY 3

[CORE] Find AI inside existing software

Task: check email, documents, CRM, meetings, design and accounting tools for built-in AI features and note whether they are switched on. **Why:** features arrive by update, often on by default. **Time:** 45 min. **Role:** Administrator. **Deliverable:** a list of AI features by product. **Done when:** each main product has been checked.

☐ DONE

DAY 4

[URGENT] Check accounts and plans

Task: for every tool, record whether the account is business or personal and which plan. **Why:** the plan decides the terms. **Time:** 30 min. **Role:** Administrator. **Deliverable:** account and plan for each tool. **Done when:** every tool has an answer, or "unknown".

☐ DONE

DAY 5

[CORE] Note purposes and data

Task: for each tool, write what it is used for and what kinds of data go in. **Why:** risk depends on the data. **Time:** 45 min. **Role:** Team leads. **Deliverable:** purpose and data notes. **Done when:** each tool has both.

☐ DONE

DAY 6

[CORE] Complete the inventory

Task: gather everything into the AI Tool Inventory (Resource 7). **Why:** the inventory is the foundation for every later step. **Time:** 30 min. **Role:** Owner. **Deliverable:** one inventory. **Done when:** it is saved where the owner and administrator can find it.

☐ DONE

DAY 7

[URGENT] Fix the obvious

Task: remove quick-win risks: shared logins, public sharing links, personal accounts holding client data, extensions with broad permissions. **Why:** it closes the easiest leaks now. **Time:** 45 min. **Role:** Administrator. **Deliverable:** a list of fixes made. **Done when:** the quick wins are closed.

☐ DONE



WEEK 2

Assess: understand the risks you have

You now know what exists. This week you judge what matters, using the tools in Chapters 2 to 4.

DAY 8

[URGENT] Set Green, Amber and Red

Task: adopt the framework from Chapter 2 and write your own "never paste" list. **Why:** people need a rule they can apply in seconds. **Time:** 45 min. **Role:** Owner. **Deliverable:** the matrix (Resource 3). **Done when:** it is shared with the team.

☐ DONE

DAY 9

[CORE] Check your top three tools

Task: run the ten-minute vendor check (Chapter 3) on the three most-used tools. **Why:** risk concentrates in a few tools. **Time:** 45 min. **Role:** Owner. **Deliverable:** three completed checks with dates. **Done when:** each answer has evidence or is marked "unknown".

☐ DONE

DAY 10

[CORE] Read the terms

Task: read the training, retention and sharing sections of the terms for each top tool, plan by plan. **Why:** the defaults may not suit you. **Time:** 60 min. **Role:** Administrator. **Deliverable:** notes with page dates. **Done when:** each note names the plan it applies to.

☐ DONE

DAY 11

[CORE] Review integrations and permissions

Task: list every connection between an AI tool and email, files, CRM, shop or accounts, and what each can read or change. **Why:** connections create standing access. **Time:** 45 min. **Role:** Administrator. **Deliverable:** an access list. **Done when:** unneeded access has been marked for removal.

☐ DONE

DAY 12

[CORE] Find high-risk workflows

Task: flag workflows involving personal data of many people, special-category data, staff or applicants, finance or client data. **Why:** these need extra care. **Time:** 45 min. **Role:** Team leads. **Deliverable:** a short list of workflows. **Done when:** each has an owner.

☐ DONE

DAY 13

[CORE] Start the risk register

Task: enter the main risks with likelihood, impact, owner and control (Resource 8). **Why:** a written register turns worry into action. **Time:** 45 min. **Role:** Owner. **Deliverable:** a first register. **Done when:** at least five risks are recorded.

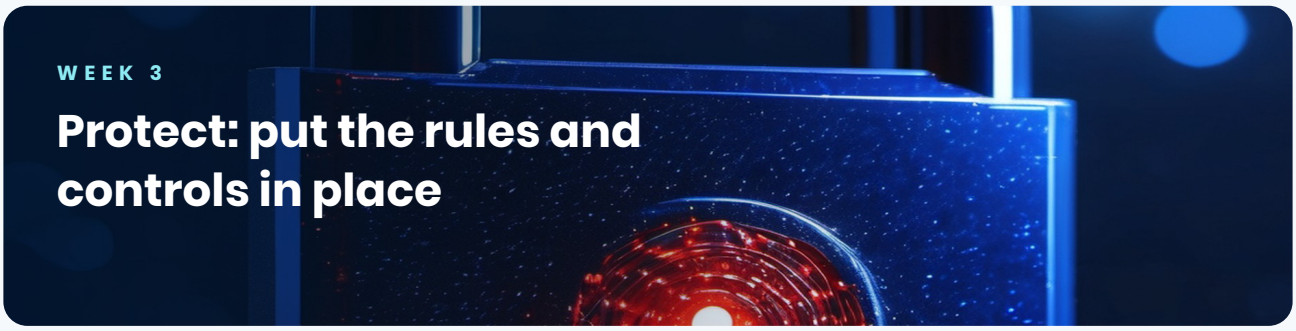
☐ DONE

DAY 14

[LATER] Check your contracts

Task: look at client contracts and NDAs for limits on third-party tools. **Why:** your duties to clients may be stricter than the law. **Time:** 45 min. **Role:** Owner. **Deliverable:** a list of clients with restrictions. **Done when:** every active client has been checked.

☐ DONE



WEEK 3

Protect: put the rules and controls in place

This week turns knowledge into habit: a policy, approved tools, safe prompts, training and a reporting route.

DAY 15

[URGENT] Adopt the policy

Task: fill in the policy template (Chapter 7), edit it to fit, and publish it. **Why:** staff need a written rule. **Time:** 60 min. **Role:** Owner. **Deliverable:** a dated policy. **Done when:** everyone has received it.

☐ DONE

DAY 16

[URGENT] Publish the approved tools list

Task: write the list of approved tools, plans and purposes, and the route for requests. **Why:** a clear yes is better than a vague no. **Time:** 30 min. **Role:** Owner. **Deliverable:** the list. **Done when:** it is shared and findable.

☐ DONE

DAY 17

[CORE] Switch settings the safe way

Task: switch off training use where a setting exists, set history retention, restrict sharing links, require multi-factor authentication. **Why:** defaults are not always cautious. **Time:** 60 min. **Role:** Administrator. **Deliverable:** a settings record with dates. **Done when:** each approved tool has been configured.

☐ DONE

DAY 18

[CORE] Create safe prompt templates

Task: write five templates with placeholders for recurring tasks (Resource 5). **Why:** a good template makes the safe way the easy way. **Time:** 60 min. **Role:** Team leads. **Deliverable:** five templates. **Done when:** they are saved in a shared place.

☐ DONE

DAY 19

[CORE] Train the team

Task: run a 30-minute briefing: the colours, the never-paste list, redaction, reporting. **Why:** a policy does not work unless people understand it. **Time:** 45 min. **Role:** Owner. **Deliverable:** attendance record (Resource 9). **Done when:** everyone has attended or has a date booked.

☐ DONE

DAY 20

[URGENT] Set up incident reporting

Task: name the incident contact, print the form (Chapter 9) and tell staff where to find both. **Why:** speed matters when something goes wrong. **Time:** 30 min. **Role:** Owner. **Deliverable:** a named contact and a form. **Done when:** each person can say whom to call.

☐ DONE

DAY 21

[LATER] Update your privacy notice

Task: check whether your customer and staff notices mention AI tools or service providers, and update them. **Why:** transparency is a legal requirement. **Time:** 45 min. **Role:** Owner. **Deliverable:** updated wording. **Done when:** it is live.

☐ DONE



WEEK 4

Verify: test, record and plan the review

The last stretch tests whether the controls work and sets up the habit that keeps them working.

DAY 22

[CORE] Run a spot check

Task: ask two staff to show how they would handle a typical task with the new rules. **Why:** a rule you cannot follow in practice is not a rule. **Time:** 30 min. **Role:** Owner. **Deliverable:** notes on what was easy and hard. **Done when:** two people have been observed.

☐ DONE

DAY 23

[CORE] Test the incident process

Task: rehearse a scenario from Chapter 6 for 20 minutes. **Why:** it exposes gaps in a calm setting. **Time:** 30 min. **Role:** Owner and contact. **Deliverable:** a short lessons list. **Done when:** gaps are logged.

☐ DONE

DAY 24

[CORE] Review outstanding risks

Task: update the register. Which risks are reduced, still open or new? **Why:** the register should show progress. **Time:** 45 min. **Role:** Owner. **Deliverable:** an updated register. **Done when:** each risk has an owner and a date.

☐ DONE

DAY 25

[CORE] Check DPAs and records

Task: confirm a DPA is in place for each tool handling personal data, and update your record of processing. **Why:** both are legal expectations. **Time:** 60 min. **Role:** Owner. **Deliverable:** a DPA list and record entries. **Done when:** every tool has either a DPA or a decision.

☐ DONE

DAY 26

[CORE] Decide if a DPIA is needed

Task: run the DPIA screening checklist (Chapter 5) on high-risk workflows. **Why:** it prevents a missed assessment. **Time:** 45 min. **Role:** Owner. **Deliverable:** a screening record. **Done when:** each flagged workflow has a decision.

☐ DONE

DAY 27

[CORE] Assign responsibilities

Task: confirm who owns the policy, inventory, tool settings, training and incident handling. **Why:** unowned tasks fade. **Time:** 30 min. **Role:** Owner. **Deliverable:** the responsibility table filled in. **Done when:** every role has a name.

☐ DONE

DAY 28

[LATER] Self-assess

Task: complete the self-assessment (Resource 12) and compare with Day 1. **Why:** you will see what changed. **Time:** 30 min. **Role:** Owner. **Deliverable:** a score. **Done when:** it is saved with a date.

☐ DONE

DAY 29

[LATER] Set the review schedule

Task: put monthly checks and a quarterly vendor review in calendars (Resource 10). **Why:** providers and rules change. **Time:** 20 min. **Role:** Owner. **Deliverable:** calendar entries. **Done when:** the next three dates are fixed.

☐ DONE

DAY 30

[LATER] Record decisions and celebrate

Task: file the policy, inventory, checks, register and records in one folder, and thank the team. **Why:** your evidence should be easy to find. **Time:** 30 min. **Role:** Owner. **Deliverable:** a "AI privacy" folder. **Done when:** everything is in it.

☐ DONE

Responsibility table

Who owns what

Responsibility	Owner (name)	Backup	Review date
Policy and approved tools list			
AI tool inventory and settings			
Vendor checks and DPAs			
Training and attendance records			
Incident contact and form			
Risk register			
Privacy notice and records of processing			

Progress tracker

DAY 01 ☐	DAY 02 ☐	DAY 03 ☐	DAY 04 ☐	DAY 05 ☐	DAY 06 ☐
DAY 07 ☐	DAY 08 ☐	DAY 09 ☐	DAY 10 ☐	DAY 11 ☐	DAY 12 ☐
DAY 13 ☐	DAY 14 ☐	DAY 15 ☐	DAY 16 ☐	DAY 17 ☐	DAY 18 ☐
DAY 19 ☐	DAY 20 ☐	DAY 21 ☐	DAY 22 ☐	DAY 23 ☐	DAY 24 ☐
DAY 25 ☐	DAY 26 ☐	DAY 27 ☐	DAY 28 ☐	DAY 29 ☐	DAY 30 ☐

Printable checklist

THE 30-DAY PLAN ON ONE PAGE

- ☐ Week 1: owner named, tools found, accounts and plans recorded, inventory complete, quick wins fixed.
- ☐ Week 2: Green, Amber and Red set, top-three tools checked, integrations reviewed, risks listed, client contracts checked.
- ☐ Week 3: policy adopted, approved list published, settings configured, templates written, team trained, incident route live, notice updated.
- ☐ Week 4: spot check done, incident rehearsal done, risks updated, DPAs and records checked, DPIA screening done, responsibilities assigned, self-assessment complete, review dates set, evidence filed.

SOURCE NOTE **When to take advice**

If the plan reveals sensitive data in prompts, high-risk uses, children's data, employee monitoring or a possible breach, pause and take specialist advice before you continue with that item.

What this means for your business

- A small daily routine beats a big project that never starts.
- Urgent first: owner, hidden tools, plans, never-paste rules, policy and reporting route.
- Verification is part of the plan. Test, then record.

GOOD PRACTICE **Chapter 11 action points**

Today: name your owner and put the 30 dates in the calendar. This week: ask your team what they use, and finish the inventory.

THE TOOLKIT

CHAPTER

12

Your AI Privacy Toolkit

Twelve editable templates, each with a purpose, instructions and fields you can fill in. In the PDF edition, the grids and sheets accept typing.

IN THIS CHAPTER

- Twelve practical resources, in the order you will need them
- How to adapt each one, and when to ask a professional to review it
- Where a resource lives elsewhere in the book, so nothing is repeated

These templates are **original and editable**. Copy them into your own documents, change the wording to fit your business, put a date on them and review them. They are not legal documents, and a template filled in does not make a business compliant. Where a template supports a legal duty, such as a DPIA, a processor agreement or a breach decision, a professional may need to review it.

The twelve resources

No.	Resource	Use it to	Where
1	AI Tool Approval Checklist	Decide whether a new tool may be used	This chapter
2	AI Vendor Privacy and Security Questionnaire	Question a provider in depth	This chapter
3	Green, Amber and Red Matrix	Tell staff what may go where	This chapter
4	Employee AI Acceptable Use Policy	Set the rules	Chapter 7 (full) and a one-page card here
5	Safe Prompt Checklist	Check a prompt before sending	This chapter
6	AI Data Exposure Incident Report Form	Record and decide on an incident	Chapter 9
7	AI Tool Inventory	List every tool and account	This chapter
8	AI Risk Register	Track risks and controls	This chapter
9	Employee AI Training Checklist	Brief and record training	This chapter
10	Monthly AI Privacy Review Checklist	Keep controls alive	This chapter
11	Redaction Checklist	Remove customer and employee data before using AI	This chapter
12	AI Privacy Self-Assessment	Measure where you stand	This chapter

Resource 1: AI Tool Approval Checklist

Purpose: a short gate before any new tool is used for work. **How to use:** the requester fills in the top; the policy owner ticks the list and records a decision and date.

AI TOOL APPROVAL CHECKLIST

☐ Requester, tool, plan, account type and purpose are written down.

- [ ] The data classes that will go in (Green, Amber, Red) are stated, and no Red data is planned.
- [ ] The tool will be used through a company account, not a personal one.
- [ ] The ten-minute vendor check (Chapter 3) has been completed.
- [ ] A DPA is in place or not needed, with a reason recorded.
- [ ] Training use, retention and sharing settings have been checked and set.
- [ ] Authentication is secured with multi-factor authentication or single sign-on.
- [ ] Connections to email, files or systems are listed, with minimum access.
- [ ] Client contracts and NDAs allow the tool for this purpose.
- [ ] Staff who will use it have been briefed.
- [ ] Decision (approve, approve with limits, reject), approver and review date are recorded.

Resource 2: AI Vendor Privacy and Security Questionnaire

Purpose: to ask a provider the questions that matter, and to keep the answers and the evidence. **How to use:** send the questions or find the answers in the provider's documentation. Record where each answer was found and when. "Unknown" is a valid answer and is itself a finding. This is a template; for significant tools take advice.

AI VENDOR PRIVACY AND SECURITY QUESTIONNAIRE

Area	Question	Provider answer	Evidence and date	Risk L/M/H
1. Identity	Which legal entity and country will we contract with, and is there an EU or UK establishment?			
2. Product	Which exact product and plan, and do terms differ for other plans?			
3. Roles	For which purposes is the provider our processor, and for which is it a controller?			
4. DPA	Is a DPA available that meets Art. 28(3), and is it part of the contract?			
5. Training	Is our content used to train or improve models, by default, by setting or by contract?			
6. Feedback	Are rated or reported conversations treated differently, and how long are they kept?			

Area	Question	Provider answer	Evidence and date	Risk L/M/H
7. Retention	How long are prompts, files and outputs kept, and who sets the period?			
8. Deletion	What does deletion remove, and how long do backups and logs persist?			
9. Human access	Can provider staff access our content, when, and under what duties?			
10. Sub-processors	Where is the list, and how will we be told of changes?			
11. Location	Where is data processed and stored? Is EU or UK processing available?			
12. Transfers	Which transfer tool applies, and what is the fallback?			
13. Security	Which certifications or audit reports exist, and can we see them?			
14. Encryption	Is data encrypted in transit and at rest? Are customer-managed keys available?			
15. Access	Are single sign-on, multi-factor authentication and role-based access supported?			
16. Logging	Can administrators see audit logs of use?			
17. Integrations	What can connectors, plug-ins and agents access, and under whose terms?			
18. Incidents	What is the commitment and timeline for notifying us of a breach?			
19. Rights	How does the provider help with access, erasure and objection requests?			
20. Exit	How do we export and delete our data when we leave?			
21. Changes	How are changes to terms, prices, tiers and features notified?			

Area	Question	Provider answer	Evidence and date	Risk L/M/H
22. AI Act	Does the provider state its role and any duties under the EU AI Act?			

Resource 3: Green, Amber and Red Matrix

Purpose: the one-page rule your team can pin up. **How to use:** replace the examples with your own, say which colours may go into which tool, and agree it with the people who do the work. It is an internal control, not a legal classification.

INFORMATION-SHARING MATRIX

Colour	Examples in our business	Approved tool?	Unapproved tool?	Conditions
RED	Passwords, keys, tokens; health data; ID documents; payment details; children's data; NDA material	No	No	Never. Exceptions only in writing, with advice.
AMBER	Customer and staff data; client files; contracts; source code; unpublished finance	Yes, with conditions	No	Minimise; redact; approved tool; log purpose; human review
GREEN	Published pages; public research; generic drafts; synthetic examples	Yes	With care	Check for hidden data; check accuracy
Our own colour 1				
Our own colour 2				

Resource 4: Employee AI Acceptable Use Policy (one-page card)

Purpose: a short summary for desks, onboarding packs and screens. **How to use:** keep it aligned with the full policy in Chapter 7. The wording below is a template.

ABOUT THIS TEMPLATE **AI at [COMPANY NAME]: the one-page card**

Use only approved tools, signed in with your company account. **Think before you paste:** Red never goes in; Amber only in approved tools, minimised and redacted; Green is generally fine. **Never paste passwords, keys or tokens. Check every output** before it is sent, published or acted on. **Do not use AI to decide about people** without approval. **Report mistakes straight away** to [NAME / CONTACT]: honest reports are welcome. **Unsure? Ask** [POLICY OWNER].

Resource 5: Safe Prompt Checklist

Purpose: ten seconds of thought before pressing Enter. **How to use:** print it, stick it to the screen, and adapt the wording.

SAFE PROMPT CHECKLIST

- [ ] No password, key, token or security answer is in the prompt.
- [ ] No special-category, children's or identity-document data is in it.
- [ ] Names, addresses, emails, numbers and order references have been removed or replaced by placeholders.
- [ ] I have used only what the task needs, not the whole thread or file.
- [ ] I have checked the file for hidden sheets, comments, tracked changes and metadata.
- [ ] The tool is approved, and I am signed in with my company account.
- [ ] The content is not under an NDA or client restriction that forbids it.
- [ ] I know who will check the output before it is used.
- [ ] I will delete the output or conversation if it holds personal data and is no longer needed.

ABOUT THIS TEMPLATE **Placeholder prompt examples**

"Draft a polite reply to a customer, [NAME], who reports that [ISSUE]. Tone: [TONE]. Do not add facts I have not given." · "Summarise the themes in these three anonymised complaints in five bullet points." · "Explain, in plain English, what a data processing agreement is."

Resource 6: AI Data Exposure Incident Report Form

The full form is in **Chapter 9**. Print or copy it and keep it with Resource 4 so that staff know where to find it. Do not duplicate it elsewhere, so that everyone uses the same version.

Resource 7: AI Tool Inventory

Purpose: a single list of what is used, by whom and for what. **How to use:** update it whenever a tool is added or removed, and check it every month.

AI TOOL INVENTORY

Tool and plan	Account type	Owner	Purpose and data colour	DPA (Y/N)	Approved?	Next review
e.g. Assistant, business plan	*e.g. Company account with single sign-on*	*e.g. Office manager*	*e.g. Draft replies; Amber (names only)*	*e.g. Y*	*e.g. Yes, with conditions*	*e.g. 15 Jan*
e.g. Transcription app, free plan	*e.g. Personal account*	*e.g. Sales lead*	*e.g. Meeting notes; Amber (voices)*	*e.g. N*	*e.g. Not approved*	*e.g. Remove*

Resource 8: AI Risk Register

Purpose: to keep the main risks, their owners and their controls in one place. **How to use:** rate likelihood and impact from 1 (low) to 3 (high); multiply for a score; review monthly.

AI RISK REGISTER

Risk	Likelihood (1-3)	Impact (1-3)	Score	Control	Owner	Due
e.g. Staff paste customer data into unapproved tools	*e.g. 3*	*e.g. 3*	*e.g. 9*	*e.g. Approved tool, rules, training*	*e.g. Owner*	*e.g. 30 Nov*

Risk	Likelihood (1-3)	Impact (1-3)	Score	Control	Owner	Due
e.g. Extension with broad access is installed	*e.g. 2*	*e.g. 3*	*e.g. 6*	*e.g. Approved extensions list*	*e.g. Administrator*	*e.g. 15 Dec*

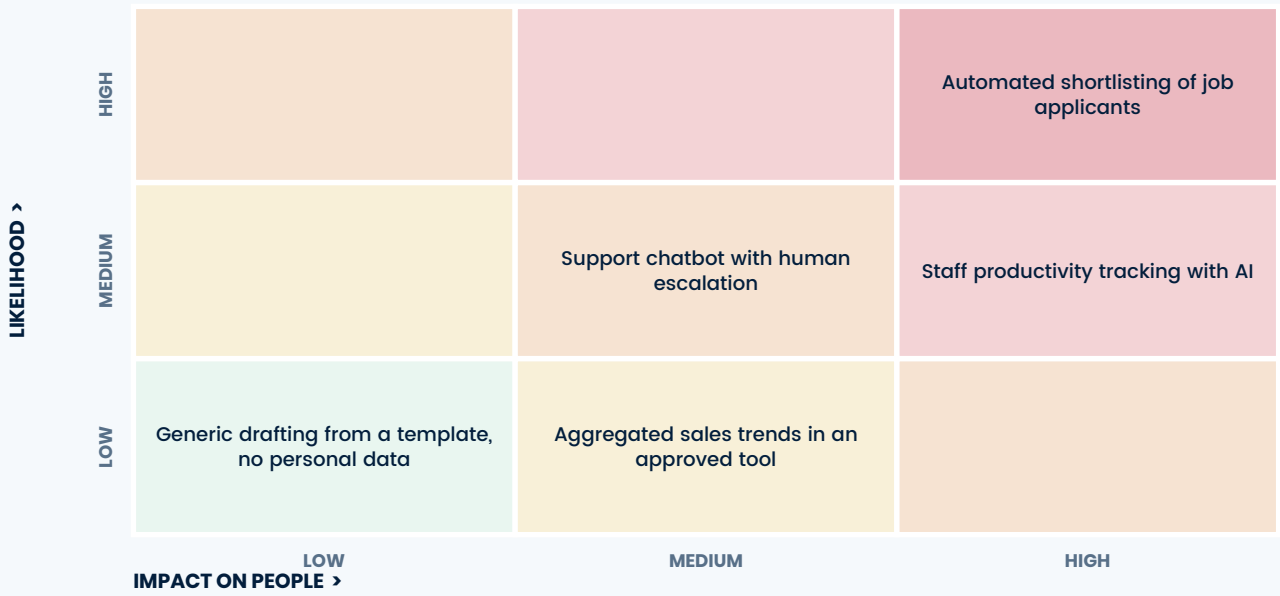


Figure 20 Rough risk matrix (likelihood 1 to 3, impact 1 to 3)

Resource 9: Employee AI Training Checklist

Purpose: a short briefing that is repeated and recorded. **How to use:** tick each topic as it is covered, and record names and dates. About 30 minutes is enough for most roles.

EMPLOYEE AI TRAINING CHECKLIST

- ☐ Why this matters: real examples of how exposure happens.

- [ ] Green, Amber and Red, with examples from our own work.
- [ ] The approved tools list, and how to request a new tool.
- [ ] Never paste credentials, ID documents or special-category data.
- [ ] How to redact and minimise before using a tool.
- [ ] Checking AI output for errors, bias and leaked detail.
- [ ] Why AI must not be used to decide about people.
- [ ] How to report a mistake, to whom, and why it is safe to do so.
- [ ] What the EU AI Act means for our work, at a level suited to the role (AI literacy).
- [ ] Attendance recorded: name, date and trainer.

Resource 10: Monthly AI Privacy Review Checklist

Purpose: thirty minutes a month that keeps the system alive.

MONTHLY AI PRIVACY REVIEW CHECKLIST

- [ ] The inventory is up to date: new tools, leavers, removed tools.
- [ ] New AI features in existing software have been checked.
- [ ] Approved tools' settings are unchanged: training, retention, sharing, multi-factor authentication.
- [ ] Extensions and integrations have been reviewed.
- [ ] Any provider notices of changed terms or sub-processors have been read.
- [ ] Incidents and near-misses have been reviewed, and lessons recorded.
- [ ] Staff leavers' accounts and access have been removed.
- [ ] The risk register has been updated.
- [ ] One quick spot check of a real task has been done.
- [ ] Next review date is set.

Resource 11: Customer and Employee Data Redaction Checklist

Purpose: to remove identifying information properly before using AI. **How to use:** work through it each time you prepare a document or data set.

1. Work on a copy. Never redact your only original.
2. Delete, do not hide. Remove columns, rows, hidden sheets, comments, tracked changes and metadata, rather than shading them white or collapsing them.

3 Replace identifiers with placeholders or codes (for example [CUSTOMER 1]). Keep any key table in a different place from the file.
4 Search the whole document for names, emails, phone numbers, postcodes, order numbers, birth dates and numbers that look like IDs, including headers, footers and file names.
5 Look for indirect identifiers: rare job titles, dates, small places, unusual events.
6 For scans and images, use a tool that burns the redaction into the image, then test by trying to select and copy the text.
7 Open the final file as a stranger would, and read it once as if you were the provider's support team.
8 Record that you redacted it, and who checked it.

Resource 12: AI Privacy Self-Assessment for Small Businesses

Purpose: a quick baseline to repeat after 30 days. **How to use:** score each statement from 0 (not true) to 5 (fully true). Add the scores.

AREA	YOUR SCORE	OUT OF
1. We know which AI tools our people use for work		5
2. Staff know what must never be pasted into AI tools		5
3. We know the plan and account type of each tool		5
4. Training, retention and sharing settings have been checked and dated		5
5. Customer and client data goes only into approved tools		5
6. A person checks AI output before it is used		5
7. Someone is responsible for AI and privacy decisions		5
8. We have a written policy and staff have read it		5
9. We know what to do, and whom to tell, if something goes wrong		5
10. We review tools, settings and risks on a schedule		5
TOTAL SCORE		**50**

0 to 15	16 to 30	31 to 42	43 to 50
Exposed	**Building**	**Organised**	**Strong start**
Do the five actions in the Conclusion and start the 30-day plan.	You have good instincts. Write decisions down and complete Weeks 2 and 3.	Test with a rehearsal and set your review dates.	Keep reviewing, and take advice on complex or high-risk uses.

Figure 21 What your total might suggest

SOURCE NOTE **Professional review may be needed**

These tools help you organise your thinking. They do not by themselves satisfy the GDPR, the UK GDPR or the AI Act. If you handle special-category data, serve regulated clients, use AI to make decisions about people, or face a suspected breach, take advice from a qualified professional.

What this means for your business

- A template used is worth more than a perfect one that is never opened.
- Date everything, keep it in one place and review it on a schedule.
- Ask a professional to review the parts that carry legal weight.

GOOD PRACTICE **Chapter 12 action points**

Choose three resources to complete this week: the inventory, the matrix and the safe prompt checklist. Save them in a shared "AI privacy" folder.

CONCLUSION

CONCLUSION

AI

Make AI Work for Your Business, Not Against It

You do not need to choose between using AI and protecting your information.

IN THIS CHAPTER

- The five lessons that matter most
- Five steps to take immediately

The story at the start of this book ended with a question nobody could answer: *where did our customer's information go?* Everything since has been about making sure you can answer it, and about making sure that, most of the time, the information never goes anywhere it should not.

What to remember

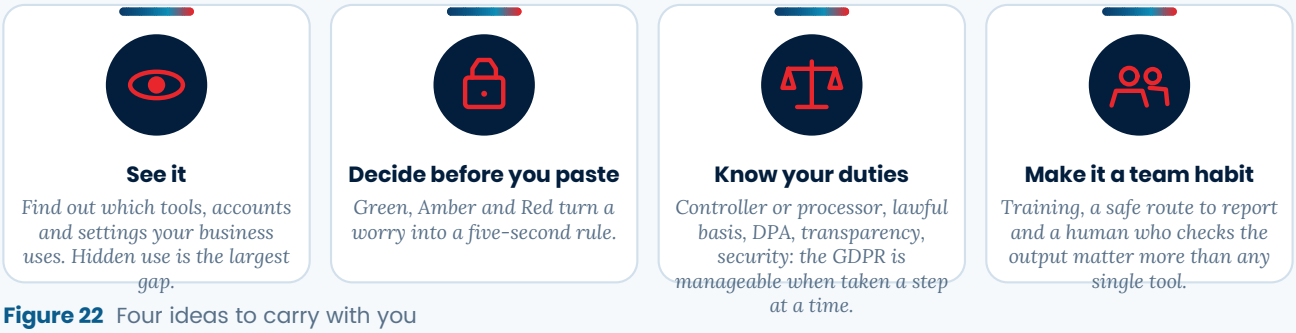


Figure 22 Four ideas to carry with you

Use AI where it genuinely helps, and keep a person in charge of the decisions that matter. Combine tool review, employee training, vendor contracts, security basics and human judgement, because no single measure carries the whole load. Keep records, because accountability is partly the ability to show your thinking. Review regularly, because providers, rules and your own business will change.

And remember what this book cannot do. It cannot make you compliant, and it cannot predict how a regulator or a client will view your facts. When the stakes are high, such as sensitive data, decisions about people or a real incident, take qualified advice.

Your five most important steps

1. **Find out what is in use.** Ask your team which AI tools they use for work, including free accounts, phone apps and extensions, and write the answers in an inventory (Resource 7).
2. **Draw the line.** Adopt Green, Amber and Red, and publish your never-paste list: credentials, special-category data, identity documents and confidential client material (Chapter 2 and Resource 3).
3. **Move work to approved, company-managed tools.** Check plan, settings, retention and the DPA for the tools you keep. Stop work on personal accounts (Chapters 3, 4 and 7).
4. **Write it down and tell people.** Adopt the policy, brief the team, and give everyone the name of the person to tell if something goes wrong (Chapters 7 and 9).
5. **Put a date in the calendar.** Review tools, settings and risks monthly and quarterly, and re-check the law's dates (Chapter 11 and Resource 10).

GOOD PRACTICE **A final thought**

AI will keep changing. The habit that protects you will not: before information goes in, ask what it is, why you are using AI, who else will handle it, and what happens to it afterwards. Ask it every time, and you will avoid most of what this book warns about.

Sources

Numbered sources used in the text. Legal research cut-off: 24 October 2026. Web pages accessed on that date unless stated.

SOURCE NOTE **How to read these sources**

Binding law is cited by instrument. **Regulator guidance** (EDPB, ICO, Commission) is not itself binding law. **Provider statements** are what each provider says about its own products on the date shown. The last column says how each source was checked in this edition: **Fetched** means the page was opened and read on 24 October 2026; **Secondary** means the primary text could not be read and the point was confirmed in at least two independent commentaries; **Working knowledge** means stable text not re-read in full for this edition. Anything marked Secondary or Working knowledge should be verified before publication or reliance.

Sources

No.	Source	Where to find it	Type and check
[1]	Regulation (EU) 2016/679 (General Data Protection Regulation), cited by article	https://eur-lex.europa.eu/eli/reg/2016/679/oj	Binding law. Read on EUR-Lex 24 October 2026 (Arts 4, 30, 33, 34 and the Art. 4(12) definition checked)
[2]	Regulation (EU) 2024/1689 (Artificial Intelligence Act), cited by article	https://eur-lex.europa.eu/eli/reg/2024/1689/oj	Binding law. Read on EUR-Lex 24 October 2026 (Arts 26, 50, 99, 113 checked)
[3]	Regulation (EU) 2026/1744 amending the AI Act ("Digital Omnibus on AI"), dated 8 July 2026, OJ L 2026/1744 of 24 July 2026, in force on the third day after publication (27 July 2026). Checked: Annex III high-risk date 2 Dec 2027 and Annex I 2 Aug 2028 (Art. 113); replaced Art. 4 (AI literacy); new Art. 5(1)(ba) and (bb) prohibitions applying from 2 Dec 2026; Art. 50(2) transition to 2 Dec 2026; Art. 99(6a)	https://eur-lex.europa.eu/eli/reg/2026/1744/oj	Binding law. Read on EUR-Lex 24 October 2026
[4]	EDPB, Guidelines 07/2020 on the concepts of controller and processor in the GDPR	https://www.edpb.europa.eu (Our work and tools, Guidelines)	Regulator guidance. Working knowledge
[5]	EDPB, Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models (December 2024)	https://www.edpb.europa.eu (Our work and tools, Opinions)	Regulator guidance. Working knowledge and summaries
[6]	EDPB, Guidelines 9/2022 on personal data breach notification under the GDPR, version 2.0 (April 2023)	https://www.edpb.europa.eu (Our work and tools, Guidelines)	Regulator guidance. Working knowledge
[7]	Article 29 Working Party, Guidelines on Data Protection Impact Assessment (wp248rev.01), endorsed by the EDPB	https://ec.europa.eu/newsroom/article29/items/611236	Regulator guidance. Working knowledge

No.	Source	Where to find it	Type and check
[8]	Commission Implementing Decision (EU) 2021/914 on standard contractual clauses for transfers to third countries	https://eur-lex.europa.eu/eli/dec_impl/2021/914/oj	Binding law. Working knowledge
[9]	Commission Implementing Decision (EU) 2023/1795 (EU-US Data Privacy Framework); General Court, Case T-553/23, Latombe v Commission (3 September 2025); appeal C-703/25 P reported as pending at the cut-off	https://eur-lex.europa.eu/eli/dec_impl/2023/1795/oj and https://curia.europa.eu	Binding law and case law. Working knowledge and secondary for the appeal
[10]	Microsoft Learn, "Data, Privacy, and Security for Microsoft Copilot" (updated 8 October 2026)	https://learn.microsoft.com/en-us/microsoft-365/copilot/microsoft-365-copilot-privacy	Provider statement. Fetched 24 October 2026
[11]	Google Workspace, "Generative AI in Google Workspace Privacy Hub" (header 6 October 2026, footer 22 October 2026)	https://knowledge.workspace.google.com/admin/gemini/generative-ai-in-google-workspace-privacy-hub	Provider statement. Fetched 24 October 2026
[12]	Anthropic Privacy Center, "Is my data used for model training?" (updated 18 August 2026)	https://privacy.claude.com/en/articles/7996868-is-my-data-used-for-model-training	Provider statement. Fetched 24 October 2026
[13]	OWASP Gen AI Security Project, LLM Top 10, LLM01:2025 Prompt Injection	https://genai.owasp.org/llmrisk/llm01-prompt-injection/	Community security guidance. Working knowledge
[14]	Information Commissioner's Office (UK), Artificial intelligence guidance pages, including "Guidance on AI and data protection"	https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/	Regulator guidance. Landing page fetched 24 October 2026, which carries no update date; the ICO notes the AI guidance is under review after the 2025 Act
[15]	UK GDPR; Data Protection Act 2018; Data (Use and Access) Act 2025 (Royal Assent 19 June 2025). The contents page was read; the statutory commencement regulations were not	https://www.legislation.gov.uk/ukpga/2025/18/contents	Binding law. Partly checked 24 October 2026

No.	Source	Where to find it	Type and check
[16]	ICO, guidance on personal data breaches and reporting	https://ico.org.uk/for-organisations/report-a-breach/	Regulator guidance. Working knowledge
[17]	Court of Justice, Case C-413/23 P, EDPS v Single Resolution Board (4 September 2025), on pseudonymised data	https://curia.europa.eu (case search)	Case law. Secondary: commentaries differ on details
[18]	Court of Justice, Case C-634/21, SCHUFA Holding (Scoring) (7 December 2023), on Art. 22	https://curia.europa.eu (case search)	Case law. Working knowledge
[19]	Directive (EU) 2016/943 on the protection of undisclosed know-how and business information (trade secrets)	https://eur-lex.europa.eu/eli/dir/2016/943/oj	Binding law. Working knowledge
[20]	NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0, NIST AI 100-1, January 2023)	https://www.nist.gov/itl/ai-risk-management-framework	Standards guidance. Working knowledge; background only
[21]	UK National Cyber Security Centre, Small Business Guide	https://www.ncsc.gov.uk/collection/small-business-guide	Security guidance. Working knowledge
[22]	Directive 2002/58/EC (ePrivacy) and, in the UK, the Privacy and Electronic Communications Regulations 2003, on electronic marketing	https://eur-lex.europa.eu/eli/dir/2002/58/oj and https://www.legislation.gov.uk	Binding law. Working knowledge
[23]	OpenAI, "Business data privacy, security, and compliance" (undated; read in its Portuguese-language version, the English page returned an access error to the automated fetch). Earlier cross-checked against the OpenAI Academy admin guide, which says the same on training and encryption	https://openai.com/business-data/	Provider statement. Read 24 October 2026

No.	Source	Where to find it	Type and check
[24]	ICO, "The Data Use and Access Act 2025 (DUAA): what does it mean for organisations?" (latest update 19 June 2026)	https://ico.org.uk/about-the-ico/what-we-do/legislation-we-cover/data-use-and-access-act-2025/the-data-use-and-access-act-2025-what-does-it-mean-for-organisations/	Regulator guidance. Fetched 24 October 2026

WATCH OUT **Not verified in this edition**

OpenAI. The business-data page was read, but its DPA text, sub-processor list, API terms and consumer-plan settings were not, and the page carries no date. **Case law and guidance.** The EDPB guidelines and opinions, the CJEU judgments (including the pending DPF appeal) and the Commission transfer decisions were cited from working knowledge and secondary sources, not re-read. **UK reform.** Which provisions of the 2025 Act are in force was taken from the ICO's page, not from the commencement regulations, and the ICO's new structure and name were not verified. **EU-UK adequacy.** Not verified.

DO THIS NOW **Before you rely on this edition**

(1) Re-check the current consolidated AI Act text on EUR-Lex, and any Commission guidelines under Arts 4 and 50. (2) Check whether any GDPR amendment from the Digital Omnibus has been adopted. (3) Check the status of appeal C-703/25 P. (4) Re-read each provider page you rely on. (5) Check the UK commencement regulations and the ICO's new structure.

About the Author and GDPRGard.eu

A short note and a pointer to further resources.

Zirlandia Milkovic writes practical guides on data protection, artificial intelligence and business safety for small teams and independent professionals. This book grew out of a simple observation: the people who most need clear rules about AI and information are the ones with the least time to write them.

GDPRGard.eu

GDPRGard.eu (https://gdprgard.eu/) is the author's resource website for European small businesses exploring GDPR compliance. You may find it useful for:

- **Educational articles** on GDPR, AI and data protection topics.
- **Practical tools and checklists** you can use to think through a data-protection question.
- **Templates and starter documents** that you can adapt for your own business.

Please treat everything there, as everything in this book, as **educational material**. It does not replace legal advice, an audit or a decision by your supervisory authority, and no tool or template can guarantee compliance. You do not need the website to use this book: every checklist, form and policy you need is inside it.

If you have corrections, updates or questions about the book, you are welcome to get in touch through the website.



Use AI.
Decide before
you paste.
Protect what matters.

ZIRLANDIA MILKOVIC